



File No.: EXP202206311

SANCTIONING PROCEDURE RESOLUTION

SANCTIONING PROCEDURE RESOLUTION

BACKGROUND.....	4
FIRST: CLAIM.....	4
SECOND: TRANSFER OF THE CLAIM.....	5
THIRD: ADMISSION OF THE CLAIM FOR PROCESSING.....	6
FOURTH: PRELIMINARY INVESTIGATION ACTIONS.....	6
FIFTH: AGREEMENT TO INITIATE SANCTIONING PROCEDURE.....	11
SIXTH: COPY OF THE FILE AND EXTENSION OF DEADLINE.....	11
SEVENTH: ALLEGATIONS TO THE INITIATION AGREEMENT.....	11
1. In CaixaBank's opinion, the allegations against it are inaccurate:.....	12
2. According to the financial entity, the interpretation made by the AEPD affects several principles of sanctioning law:.....	14
3. Regarding the alleged non-compliance with data protection obligations by design:.....	16
4. Regarding the alleged violation of Article 32 of the GDPR:.....	18
5. Regarding the alleged violation of the principle of security:.....	19
6. Regarding the alleged violation of the principle of proportionality:.....	20
EIGHTH: EVIDENCE PRACTICE PERIOD.....	22
a. Before the respondent:.....	22
b. Before the AEPD Inspection:.....	29
NINTH: PROPOSAL FOR RESOLUTION.....	31
TENTH: ALLEGATIONS TO THE PROPOSAL FOR RESOLUTION.....	32
I. The banking entity believes that the proposal for resolution makes a series of inaccurate considerations:.....	32
II. CaixaBank insists that the proposal violates the principle of non bis in idem...33	
III. The claimant party reiterates that, in its opinion, there is a medial concurrence among the three infractions attributed to the banking entity.....	33
IV. In the opinion of the banking entity, none of the three infractions considered in the proposal for resolution are in accordance with the law.....	34
C/ Jorge Juan, 6	
www.aepd.es	
28001 – Madrid	
sedeagpd.gob.es	
2/121	
V. CaixaBank claims to have adopted the appropriate technical and organizational measures to prevent the recurrence of the personal data breach in the future.....	34
VI. The responding party insists again on the violation of the principle of proportionality.....	34
PROVEN FACTS.....	35
INDEX OF PROVEN FACTS.....	35
FIRST:.....	35
SECOND:.....	35
THIRD:.....	36
FOURTH:.....	36
FIFTH:.....	36
SIXTH:.....	36
SEVENTH:.....	37
EIGHTH:.....	37

NINTH:	38
TENTH:	38
ELEVENTH:	38
TWELFTH:	39
THIRTEENTH:	40
FOURTEENTH:	41
FIFTEENTH:	41
SIXTEENTH:	41
SEVENTEENTH:	41
EIGHTEENTH:	42
NINETEENTH:	44
TWENTIETH:	44
TWENTY-FIRST:	46
TWENTY-SECOND:	47
TWENTY-THIRD:	47
TWENTY-FOURTH:	48
TWENTY-FIFTH:	48
TWENTY-SIXTH:	49
TWENTY-SEVENTH:	52

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/121

TWENTY-EIGHTH:	54
TWENTY-NINTH:	55
THIRTIETH:	56
THIRTY-FIRST:	56
THIRTY-SECOND:	56
THIRTY-THIRD:	57
THIRTY-FOURTH:	57
THIRTY-FIFTH:	58
THIRTY-SIXTH:	59
THIRTY-SEVENTH:	59
THIRTY-EIGHTH:	60
THIRTY-NINTH:	60
FORTIETH:	61
FORTY-FIRST:	62
FORTY-SECOND:	62
FORTY-THIRD:	64
FORTY-FOURTH:	65
FORTY-FIFTH:	66
FORTY-SIXTH:	67
FORTY-SEVENTH:	67
FORTY-EIGHTH:	68
FORTY-NINTH:	69
FIFTIETH:	69
FIFTY-FIRST:	70
FIFTY-SECOND:	71
FIFTY-THIRD:	71
LEGAL GROUNDS	72
I Jurisdiction	72
II Path of the claim	72

III Allegations regarding the initiation agreement and the resolution proposal.....	78
Response to the alleged violation of the principle of non bis in idem:.....	78
IV Response to the allegation regarding the supposed existence of a media contest among the three infractions attributed to CaixaBank:.....	84
C/ Jorge Juan, 6	
www.aepd.es	
28001 – Madrid	
sedeagpd.gob.es	
4/121	
V Analysis of the violation of Article 5.1 f) of the GDPR.....	91
VI Analysis of the violation of Article 32 of the GDPR.....	103
VII Analysis of the violation of Article 25 of the GDPR.....	113
1. Content of the principle of privacy by design and internal conditions for its compliance.....	114
2. Analysis of the design of the procedure that articulates the processing of documents submitted by the data subjects of CaixaBank that affect the protection of personal data.....	118
3. Design of the document storage path generation system (also referred to as path HCP) related to CaixaBank's banking operations:.....	124
4. Analysis of the design of what happens in the system when an error code is generated after deactivating the archiving versioning:.....	133
VIII Alleged violation of the principle of proportionality.....	143
IX General issues related to the protection of personal data.....	149
X Article 5.1.f) of the GDPR.....	150
XI Classification of the infringement of Article 5.1.f) of the GDPR and qualification for the purposes of prescription.....	151
XII Sanction for the infringement of Article 5.1.f) of the GDPR.....	151
XIII Article 25.1 GDPR.....	155
XIV Classification of the possible infringement of Article 25 GDPR and qualification for the purposes of prescription.....	159
XV Sanction for the infringement of Article 25 of the GDPR.....	160
XVI Article 32 of the GDPR.....	163
XVII Classification of the infringement of Article 32 of the GDPR and qualification for the purposes of prescription.....	164
XVIII Sanction for the infringement of Article 32 of the GDPR.....	164
XIX Imposition of measures.....	166

From the procedure instructed by the Spanish Agency for the Protection of Data and based on the following

BACKGROUND

FIRST: COMPLAINT

On May 10, 2022, a complaint from A.A.A. (hereinafter, the complainant) was entered into the General Registry of the Spanish Agency for the Protection of Data, transferred by the Conduct of Entities Department of the Bank of Spain, to which it was submitted on February 10, 2022.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/121

The claim is directed against CAIXABANK, S.A. with NIF A08663619 (hereinafter, the claimed party, the banking entity, or CaixaBank). The reasons on which the claim is based are as follows:

The claiming party, a client of CaixaBank, believes that this banking entity does not respect the rules regarding the confidentiality of personal data.

It indicates that, in its personal area, specifically in the section corresponding to "(...)", there is a

document (dated February 1, 2021) related to a transfer made by a third party to another unknown person (which contains numerous personal data, such as ID number, postal address, bank account number, etc.).

As a result of what occurred, it has filed a complaint with the aforementioned banking entity. The claiming party states that CaixaBank has not responded regarding the facts subject to the claim. Along with the claim, it provides several screenshots showing proof of transfer orders from March 2021, as well as a document titled Data Update dated February 1, 2021, a copy of the document related to the request for issuance of the disputed transfer (dated February 1, 2021), an email confirming the receipt of the complaint made, and a response from the claimed party, dated November 10, 2021, which states the following:

"We are writing to you in response to your complaint, which expresses your disagreement with some receipts charged to your account and not authorized (...). In this regard, once the appropriate checks have been carried out, we must inform you that CaixaBank merely charges the receipts according to what the issuer of the payment order indicates. Therefore, you should contact the issuing company of the receipt to request the corresponding direct debit order.

Thus, we understand that your request has been satisfied, and we consider our action in this matter concluded, (...)"

SECOND: TRANSFER OF THE CLAIM

In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the claim was transferred to the claimed party, so that it could proceed with its analysis and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 08/06/2022 as evidenced by the acknowledgment of receipt in the file.

On 26/07/2022, this Agency received a letter, accompanied by a copy of the letter dated July 22, 2022, sent to the claimant in response to their complaint, in which the following is indicated:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/121

"We are contacting you to address a complaint that was forwarded to us by the Spanish Agency for Data Protection (...)

Regarding your complaint in which you state that (...) there is a document, dated February 1, 2021, that does not correspond to any operation carried out by you, we must inform you of the following:

(i) On the indicated date (February 1, 2021), it is recorded that you carried out the following operation (Document No. 1):

(...)

(...).

(...).

(...).

THIRD: ADMISSION OF THE CLAIM FOR PROCESSING

On August 10, 2022, in accordance with Article 65 of the LOPDGDD, the claim submitted by the claiming party was admitted for processing.

FOURTH: PRELIMINARY INVESTIGATIVE ACTIONS

The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware, among other things, of the following aspects:

INVESTIGATED ENTITIES

During the present actions, the following entities have been investigated:

CAIXABANK, S.A. with NIF A08663619 located at ADDRESS.1 VALENCIA (VALENCIA)

RESULT OF THE INVESTIGATIVE ACTIONS

Representatives of the claimed entity state that, according to what the Claimant indicated, the (...) did not correspond to the operation carried out. They also indicate the following:

(...)

The claimant has been informed by letter sent by certified mail with acknowledgment of receipt. (...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/121

Regarding the outcome of the analysis conducted on this incident and whether it has been detected that there could be a breach of personal data affecting other clients, the representatives of the entity inform that:

"a) (...):

(...).

b) (...)"

In relation to the breach of personal data, the representatives of the entity provide the following information:

(...).

(...)

(i)

(...)

(ii)

(...)

(iii)

(...)

(iv)

(...).

As for the actions taken as a consequence of this specific event, they were:

a) (...).

b) (...).

c) (...).

d) (...).

e) (...).

(...).

(...).

CONCLUSIONS

The fact that the claimant had access to (...) a document related to a transfer from a third party (which contains numerous personal data of said third party, the orderer of the transfer, as well as the recipient of the same, such as ID number, postal address, bank account number, etc.) is due to a breach of personal data (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/121

The party being claimed indicates that the cause of the breach is motivated by two operations (the one carried out by the claimant and by a third party) (...).

For this reason, the claimant could access a transfer receipt made by a third party.

According to their assessment (...), however, as a solution (...).

This breach of personal data affected the operation carried out by the Claimant, who had access to data from third parties (the orderer and the recipient of the transfer). CaixaBank has conducted an analysis indicating that this operation has not affected more clients.

From the analysis of the information provided, it appears that the origin of the incident was due to (...).

To each of the few operations that may (...).

The way to resolve the incident, (...).

FIFTH: AGREEMENT TO INITIATE SANCTIONING PROCEDURE

On January 27, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate a sanctioning procedure against the claimed party, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP):

- For the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR.
- For the alleged infringement of Article 25 of the GDPR, classified in Article 83.4 of the GDPR.
- For the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR.

SIXTH: COPY OF THE FILE AND EXTENSION OF DEADLINE

Notified of the aforementioned initiation agreement in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), on February 6, 2023, the claimed party requested a copy of the file, as well as an extension of the deadline to submit allegations.

On February 8, 2023, the file was sent to the claimed party, granting at the same time a new deadline to submit allegations.

SEVENTH:

ALLEGATIONS TO THE INITIATION AGREEMENT

The claimed party submitted a written statement of allegations to the initiation agreement in a document dated February 20, 2023, in which, in summary, it stated the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/121

CaixaBank considers that the initiation agreement is based on mere conjectures, stemming from an alleged infringement of Article 25 of the GDPR (lack of privacy by design), from which the alleged infringement of two other articles of the GDPR (5.1 f) and 32) would derive.

CaixaBank asserts throughout its statement of allegations that the personal data protection regulations have not been violated.

It begins its allegations by interpreting the content of the initiation agreement, which it considers indicates that the entity has violated Articles 5.1 f), 25, and 32 of the GDPR.

According to the interpretation of this entity, the agreement understands that the entity has not complied with the obligations of the principle of data protection by design (Article 25.1 of the GDPR), which in turn would have resulted in a breach of the principle of confidentiality and security and would have led to an alleged absence of appropriate technical and organizational security measures to guarantee the protection of the fundamental right to personal data protection.

The claimed party emphasizes that this all stems from a specific complaint, arising from the fact that (...) a document that belonged to another client of the mentioned banking entity.

This reported circumstance arises from an error whose probability, according to the financial entity, is (...).

The initiation agreement is based on the conclusions of the preliminary investigation report, assessing that the financial entity has not carried out any privacy by design actions, resulting in a breach of the security principle due to the absence of adequate security measures.

In CaixaBank's opinion, the AEPD relies on mere conjectures contained in the preliminary investigation

report, which are translated into the alleged commission of three infringements, punishable by a total amount of five million euros.

1. In CaixaBank's opinion, the accusations directed against it are inaccurate:

According to the financial entity, the AEPD bases its accusations against said entity for the commission of three infringements that would be punished with a total of five million euros on:

- (...).

- (...).

- (...).

(...).

a. Regarding the probability of recurrence of the incident:

The conclusions of the preliminary investigation report consider (...).

According to CaixaBank:

"As my represented party indicated in response to the request made by that AEPD (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/121

Next, the financial entity highlights that in the subject matter of the complaint, not only did the (...) occur.

The financial entity emphasizes that the AEPD considers that the probability of this fact recurring over time (it highlights that no periodicity or degree of occurrence has been indicated) is "reasonable," (...).

It then performs a series of calculations that lead to the conclusion that, according to said financial entity, the probability of recurrence of the incident would be (...). Furthermore, it states that (...).

CaixaBank provides its regulatory framework regarding security. This circumstance, in the opinion of said banking entity, demonstrates compliance with the principle of privacy by design.

b. Regarding the

(...)

:

The Inspector concludes in his report of preliminary investigation actions that (...).

The financial entity indicates:

"The conclusion, always conditionally, reached by the Inspector seems to be that if in a specific case (...), which allows the Agreement of Initiation to draw the consequence that the measures adopted by CAIXABANK do not comply with the regulations on personal data protection."

(...).

(...).

CaixaBank understands that the documentation provided demonstrates (...).

c. Regarding the measure adopted to resolve the incident:

CaixaBank criticizes the AEPD for qualifying the solution adopted once the incident was detected as a "mere patch."

It highlights that the initiation agreement shifts from the possibility (reflected in the conclusions of the preliminary investigation report) that the adopted solution was insufficient to categorically considering it "unsatisfactory" and incapable of resolving the indicated problem.

According to the banking entity, this conclusion is unfounded, given that the adopted solution (...).

CaixaBank then concludes that it will not be possible for the incident to occur again.

According to the financial entity, (...) it was the solution and not a "mere patch." Subsequently stating: "(...) (...)".

It provides document (...).

Concluding that, in its opinion, the adopted solution definitively resolves the problem.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

It also emphasizes that the conjectures that serve as the basis for the initiation agreement are, in its opinion, not aligned with the reality of the facts and the documentation presented demonstrates that they are inaccurate.

2. According to the financial entity, the interpretation made by the AEPD affects several principles of sanctioning law:

In its opinion:

“(…) the Agreement of Initiation considers (i) that my client has not adopted appropriate technical and organizational measures by design; (ii) that my represented party has not adopted such measures; and (iii) that the principle of security is not fulfilled, due to the failure to adopt the aforementioned measures.”

a. Alleged violation of the principle of non bis in idem:

In CaixaBank's opinion, in the initiation agreement, the AEPD has considered that in this case there has been an insufficiency of security measures, which would imply a triple violation of the GDPR:

- Appropriate technical and organizational measures have not been adopted (art. 32.1 of the GDPR).
- The absence or insufficiency of such measures leads to the conclusion that CaixaBank has not complied with the requirements derived from Article 25.1 of the GDPR.
- Article 5.1 f) of the GDPR would have been violated, of which Article 32 of the GDPR is merely a specification.

It then analyzes various occurrences that, in its opinion, occur:

Concurrence of Articles 5.1 f) and 32 of the GDPR:

To this end, it reproduces several excerpts from the initiation agreement. It then concludes that, in its opinion, the aforementioned agreement imposes two different sanctions as a consequence of the same facts: the lack of security measures. A reiteration of sanctions occurs, which is prohibited by sanctioning administrative law.

It states that, if the criterion maintained by the AEPD in the initiation agreement were to be followed, any violation of a provision of the GDPR would imply not only the commission of the infringement of that provision but also of the principle of data protection from which the violated norm derives.

Concurrence of Articles 25 and 32 (and 5.1 f) of the GDPR:

CaixaBank reproduces an excerpt to illustrate a supposed reiteration of sanctions concerning the imputations of Article 25 and Article 32.

It then emphasizes that considering the scope of compliance with the principle of privacy by design according to the AEPD and the European Data Protection Board, if the reasoning reflected in the initiation agreement were followed, any violation of data protection regulations by a controller would necessarily entail the violation of the principle of data protection by design.

According to CaixaBank, except in those cases where it can be appreciated that compliance with the obligations established in Article 25 has been disregarded, the san-

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Simultaneous consideration of certain facts due to the inadequate fulfillment of one of the principles of Article 5 of the GDPR and for the violation of Article 25 of the GDPR would imply a violation of the principle of non bis in idem. CaixaBank concludes by stating that in the initiation agreement, the AEPD considers that the same fact (alleged insufficiency of security measures that have generated a specific and concrete incident) would constitute three violations of the same protected legal interest: the adequate guarantee of the rights and freedoms of the affected parties.

On one hand, it would be sanctioning the absence of the measures that the AEPD considers necessary to adopt (...), the breach of the security principle (which requires the adoption of such measures), and finally, that such measures were not adopted from the design of the processing. The

initiation agreement employs similar reasoning when justifying the alleged commission of the three violations, and the circumstances that the AEPD has considered concurrent in the three cases are similar (legal grounds VI, IX, and XII). The banking entity understands that the sanctioned conduct is the same and the sanctioned fact is also the same. It asserts that it intends to sanction the absence of the measure, the lack of planning for it, and the resulting outcome.

It concludes that there would be a triple identity of subject, fact, and protected legal interest, and the principle of non bis in idem (or non ter in idem) should be applied. In its case, only one of the three sanctions should be imposed (Article 32 GDPR).

b. Subsidiarily, existence of medial concurrence among the three alleged conducts:

In CaixaBank's opinion, each of the three alleged violations would be subsumed and embedded in the others, resulting in medial concurrence (Article 29.5 of Law 40/2015, of October 1). It considers that this entity cannot be sanctioned for all the violations, given that the commission of the alleged violation of Article 25.1 of the GDPR would necessarily imply the commission of the violation of Article 32.1 of the GDPR, with this latter non-compliance leading to the alleged violation of Article 5.1 f) of the GDPR.

The banking entity understands that a triple sanction is being imposed for the same facts. It further states:

"(...) the lack of application of the measures referred to in Article 32.1, and therefore the alleged violation of Article 5.1 f) would necessarily and inseparably arise from the alleged lack of conception or design of the same at the time of determining the means and purposes of the processing. Thus, the AEPD would consider sanctionable the lack of design of a specific security measure, its lack of application, and the very principle that the adoption of that measure aims to protect, which obviously could only arise from that lack of prior design, thus meeting the requirements necessary for the appreciation of medial concurrence in this case.

Therefore, either the same facts are being sanctioned three times, or two of the violations can only be, necessarily, a consequence of the first."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/121

Next, it cites Judgment 339/2015 of September 25, 2015, of the National Court (rec. 262/2014), which in turn cites the Judgment of the Supreme Court of February 8, 1999 (rec. 9/1996).

CaixaBank concludes that in the event that it is understood that the infringements mentioned in the initiation agreement have been committed, Article 29.5 of the LRJSP would apply, such that all infringements should be subsumed under the one from which the others arise.

3. Regarding the alleged non-compliance with data protection obligations by design:

CaixaBank asserts that it has not violated Article 25 of the GDPR.

a. Scope of the principle of data protection by design:

The banking entity refers to Guidelines 4/2019 of the European Data Protection Board, reproducing part of them to conclude:

"(...) the EDPB conceives Privacy by Design as a holistic process, which encompasses the evaluation of each and every aspect of the processing, in order to ensure compliance with the principles and guarantees established in Article 5 of the GDPR. Thus, only in the event that the supervisory authorities could appreciate that a data controller has not carried out that process in its entirety, or has only developed it as a mere formality, without applying the process to the specific processing of personal data under analysis, could non-compliance with the provisions of Article 25 be appreciated. That is to say, the obligation of compliance with Article 25.1 of the GDPR is not conceived by the EDPB as an obligation of result, in the sense that it could be considered that the results derived from its execution are compliant with what is established in the GDPR, but rather as an obligation of analysis, so that if a data controller has adequately carried out the same, even if the result could be erroneous in the opinion of the supervisory authority, there would not be a violation of the principle of

Privacy by Design, but, where applicable, of one of the principles established in Article 5 of the GDPR or of the norms in which those principles are specified.

To put it graphically, and as has been pointed out previously, it is possible that from the analysis of the processing carried out by a controller, a scope of compliance with the duty of transparency may arise that is subsequently not considered sufficient by the supervisory authority, understanding that the information provided to the data subjects is not adequate. However, this would not imply that the entity in question had not fulfilled its obligation to adopt the necessary measures to comply with the principle of transparency, but rather that this principle would not be considered fully respected by the AEPD. That is to say, the result of that appreciation would be a violation of Articles 5.1 a), 13, and 14 of the GDPR, but not a violation of its Article 25. There would be no grounds to sanction the lack of privacy by design, but rather the alleged non-compliance with the principle or the norm in which it is specified. And this circumstance is what occurs in the present case: my client has fully analyzed and evaluated all the measures that should be adopted to ensure compliance with the principles established in Article 5 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/121

A different issue, denied by my client, will be whether the AEPD considers that one of the security measures adopted by my principal is insufficient. In that case, it may be appreciated that adequate measures have not been adopted, but in no case can this alleged insufficiency be considered a breach of what is stipulated by Article 25.1 of the GDPR.”

b. Content of the initiation agreement:

According to CaixaBank, the legal basis VII of the initiation agreement merely appears to outline the reasons why the AEPD understands that this entity has not complied with the principle of privacy by design.

It is deemed merely apparent, as this basis consists solely and exclusively of a description of what the AEPD considers should be regarded as the principle of data protection by design.

Below, it reproduces excerpts from legal basis VII.

In CaixaBank's opinion, the initiation agreement seems to imply that this entity has not carried out any activity in which it has assessed the risks to the rights and freedoms that could arise from (...) in relation to which the incident occurred.

On the other hand, once the breach was detected, the measure adopted, consisting of (...), is considered “a mere patch.”

All of this, according to CaixaBank, is reasoned by the AEPD solely and exclusively on the basis of the conclusions of the preliminary investigation report, which this entity believes it has disproven through the documentation provided along with the statement of objections.

CaixaBank considers that this entity did not ignore the risks generated as a consequence of (...), and that the measure adopted is not a “mere patch” that did not definitively resolve the incident.

According to this financial entity:

“In this way, it is not possible, as intended by the Initiation Agreement, to consider that my principal did not take into account (...) and at the moment following the security breach, (...) that minimized the impact or the risks that the processing of the data could generate on the rights of the data subjects and, particularly, on their right to the protection of personal data.”

CaixaBank concludes that in the analyzed case, there has been no breach of the obligations of data protection by design required of CaixaBank. This entity has developed an “amalgamation of internal rules and procedures” aimed at achieving this objective, provided along with its statement of objections to the initiation agreement.

4. On the alleged violation of Article 32 of the GDPR:

CaixaBank reproduces an excerpt from legal basis X, which in its view, again falls into the maximalism of understanding that once an incident occurs whose probability of occurrence is practically non-existent, this circumstance determines that the aforementioned entity has not adopted sufficient

security measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/121

aware to preserve the rights of the interested parties and guarantee the confidentiality and availability of the data.

Next, the banking entity states:

“Thus, the AEPD in the Agreement links the alleged non-compliance with the provisions of Article 32 to the outcome that unfortunately occurred as a result of the concurrence of a series of factors that, as indicated, were unpredictable.

And at this point, CAIXABANK respectfully considers that the AEPD errs in considering that the current Data Protection regulations impose, regarding the adoption of security measures, an obligation of result, understanding that this party believes the evident spirit of the legislator, when establishing the principle of proactive responsibility, is to enact an obligation of means. That is to say, the assessment of the existence of security measures in this case does not depend, as the Agreement of Initiation seems to suggest, on whether or not a security incident has occurred, but rather on the existence of such measures and the actions taken by my represented party aimed at their determination.”

Subsequently, it refers to the Judgment of the Supreme Court of February 15, 2022 (cassation appeal: 7359/2020) which states that the obligation imposed by the personal data protection regulations to adopt technical and organizational measures aimed at ensuring the confidentiality, availability, and integrity of information is an obligation of means and not of result, and reproduces part of its legal foundation third.

CaixaBank believes that the sanctioning file should be archived, as the premises on which the AEPD relies to consider that there has been an alleged violation of Article 32 of the GDPR fall before the reality of the facts.

It insists that the initiation agreement bases its reproach on two of the conclusions of the preliminary investigation report ((...)), which, according to CaixaBank's interpretation, led to the claim that (...). The banking entity states that both conclusions have been dismantled in the written allegations and thanks to the documentation provided along with it.

It criticizes that the initiation agreement categorically states that CaixaBank did not have appropriate technical and organizational measures to guarantee an adequate level of security to the risk (...).

Next, it insists once again on a possible violation of the principle of non bis in idem.

5. On the alleged violation of the principle of security:

According to CaixaBank's interpretation, the legal foundation V of the initiation agreement bases its reproach regarding an alleged violation of Article 5.1f) of the GDPR on three arguments that, in practice, can be summarized in two:

“First, it is indicated that the conduct is sanctionable because the incident ‘has revealed a problem that affected the design (...)’. And this leads the Agreement to add: ‘(...)’.

Thus, the cited legal foundation concludes by indicating that ‘what initially seemed like a breach of confidentiality goes further as it is also a breach of availability. But, in addition, what has been verified from the preliminary investigation actions is that (...)’.

CaixaBank claims to have demonstrated in its first allegation that none of the circumstances that the initiation agreement considers evidently occurred have taken place.

1. There is a single complaint.

2. The solution provided by the entity on ***DATE.1 cannot be classified as a “mere patch,” given that the repetition of the same is impossible (...).

3. There is no violation of the principle of security as the AEPD claims.

It reiterates the violation of the principle of non bis in idem.

Next, CaixaBank denies that a breach of availability has occurred in the analyzed case, adding:

“(…)”.

It cites two documents provided along with the written allegations to the initiation agreement.

CaixaBank again insists on the advisability of archiving the sanctioning procedure.

6. On the alleged violation of the principle of proportionality:

Subsequently, it refers to the fact that this principle must be taken into account when determining the sanction to be imposed.

It refers to the content of the Judgment of the Supreme Court of November 20, 2001 (cassation appeal: 7686/1997) in relation to the principle of proportionality.

In CaixaBank's opinion, the AEPD must assess that we are dealing with a single complaint made by a single CaixaBank customer, not related to their own data, but to that of a third party, related to a specific and determined situation: access to a document belonging to someone other than the complainant. Two of the infringements established by the GDPR for the mentioned conduct are included in Article 83.4.

The financial entity highlights that the AEPD does not hesitate to impose on this entity three sanctions, some of which are subsumable into others, for a total amount of five million euros, resorting to criteria, in its opinion, completely generic, which it flatly rejects.

Moreover, the criteria used for the aggravation of one of the infringements are literally reproduced in the others, concluding that the arguments are perfectly interchangeable among the legal foundations VI, IX, and XII.

a. Regarding the alleged seriousness of the conduct:

CaixaBank states that the initiation agreement takes into account in the legal foundations VI, IX, and XII, three essential elements that it considers concurrent for the aggravation of the conduct:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/121

1. The AEPD appreciates that we are faced with (...):

This reproach would be, according to the interpretation of the initiation agreement by CaixaBank, the essential justification for the accusation made regarding the alleged violation of Article 25.1 of the GDPR.

The financial entity asserts that the identification of a supposed failure (...) is not only constitutive of one of the sanctionable types but also aggravates the responsibility in the other two (violation of the principle of non bis in idem).

2. Prolongation of the incident over time:

The financial entity highlights that it cannot determine whether the initiation agreement refers to the personal data breach that is the subject of the complaint (...).

3. Potential impact of the incident on all CaixaBank customers:

It considers the reference made by the initiation agreement to the Guidelines 4/2022 of the European Data Protection Committee as inadmissible.

b. Alleged negligence in CaixaBank's actions:

It emphasizes that the initiation agreement practically reproduces the reasons that justify the application of this aggravating factor, again referring to the close connection, which from its point of view, exists between the three violations.

1. The AEPD considers that the solution applied to resolve the incident was a "mere patch":

CaixaBank claims to have demonstrated that the (...) was not a temporary solution but a definitive one that prevented the incident from recurring.

The financial entity highlights that the resolution of the incident occurred shortly after the incident took place, as (...).

According to CaixaBank, the fact reflected in the previous paragraph prevents the arguments linking the alleged negligence in the actions of the banking entity with the temporal duration of the violation from being admitted. Furthermore, this circumstance is already considered as an aggravating factor in the section related to the nature and severity of the violation.

c. Linkage of CaixaBank's activity with the processing of data:

The banking entity considers that the initiation agreement literally reproduces in the motivation of the legal grounds VI, IX, and XII that the sanction should be aggravated as a consequence of CaixaBank's linkage with the processing of data.

The initiation agreement considers this circumstance to reinforce the potential impact on the facts and subsequently aggravates the conduct from the perspective of the alleged negligence and, finally, it is considered that it is in itself another aggravating factor, which implies a triple aggravation derived from the same fact.

As it emphasizes, in the opinion of the AEPD, when a financial entity commits an alleged violation, its conduct must be triply affected by the mere fact of belonging to the financial sector, which can hardly be considered in accordance with the principle of proportionality.

CaixaBank concludes that the imposition of three sanctions of the amount reflected in the initiation agreement can only be considered disproportionate and a violation of the principle of proportionality, especially considering that they are based on the detection of a single incident.

Finally, CaixaBank requests the filing of the sanctioning procedure or, subsidiarily, the imposition of a warning or admonition or a significant reduction of the amount established in the initiation agreement. It also invokes the confidentiality and business secrecy of the documents provided.

EIGHTH: PERIOD OF EVIDENTIARY PRACTICE

On June 7, 2023, it was agreed to open a period of evidentiary practice.

It was also agreed:

- To consider reproduced, for evidentiary purposes, the complaint filed by Mr. A.A.A. and its documentation, the documents obtained and generated during the admission phase of the complaint, as well as those obtained and generated during the preliminary investigation phase and the report of preliminary investigations, which are part of the ***PROCEDURE.1.
- To consider reproduced, for evidentiary purposes, the allegations to the initiation agreement of the referenced sanctioning procedure, submitted by CAIXABANK, S.A., and the documentation accompanying them.

The following evidentiary proceedings are carried out:

a. Before the accused:

Evidentiary Practice I:

1. In the same document dated June 7, 2023, in which the opening of a period of evidentiary practice is communicated, it is required to send the following information and documentation regarding the personal data breach, which allowed the claimant to view the proof of a transfer made by a third party in the corresponding section of (...):

- Indicate the date on which CaixaBank determined the cause of the personal data breach, which allowed (...). Provide dated and signed documentary evidence.
- Indicate the date on which (...). Provide dated and signed documentary evidence.
- Provide the document that displayed the originator of the transfer (...).

19/121

- In the document from that entity dated December 13, 2022, sent following a request from the inspector, it was indicated:

"(...)."

Provide a certificate dated and signed certifying all the information contained in the incident register of CaixaBank related to the personal data breach that allowed the claimant to view the receipt of the transfer made by another client of that banking entity, as well as the report prepared by that banking entity regarding said breach, dated and signed.

Additionally, provide the first communication dated and signed addressed to the Data Protection Officer of that banking entity related to the personal data breach analyzed in this file and referenced in the previous paragraph.

- In relation to the system (...), which, according to its letter of December 13, 2022 from this financial entity, (...), indicate and certify the period of time (prior to ***DATE.1) during which it was (...).
- Indicate in detail what happens once (...) provided by this financial entity along with its written

allegations. Once the client views (...).

- Indicate the reason why that banking entity decided (...). Provide a document dated and signed reflecting that the deactivation occurred on that date and the reason for which it was decided to carry out said deactivation.

- Indicate whether as a consequence of the personal data breach, which allowed the claimant access to the receipt of a transfer made by another client of that banking entity, any different measures have been taken by that entity (...). In case of an affirmative response, provide:

1. Description of the measure taken.

2. Date on which said measure was carried out.

3. Provide dated and signed documentation certifying said measure.

- Indicate whether that entity, from the date it detected the analyzed personal data breach, has carried out any measures aimed at (...). In case of an affirmative response:

1. Description of the measure taken.

2. Date on which said measure was adopted.

3. Provide dated and signed documentation certifying the adopted measure.

- Indicate whether any measures have been taken by that banking entity, from the date it detected the analyzed personal data breach, aimed at (...).

1. Description of the measure taken.

2. Date on which said measure was adopted.

3. Provide dated and signed documentation certifying the adopted measure.

- Provide the risk analyses and definitions of security requirements (...), that were involved in the personal data breach being analyzed in this file, regarding the breach that allowed the claimant to view the receipt of the transfer made by another client (the documents prepared before February 1, 2021 are requested and, if applicable, those prepared after that date). The documents must be submitted dated and signed, and in the case of having different versions, provide all of them.

- In the document (...) it is indicated:

Article 1. (...)

(...)

b) (...).

Documentarily certify the mechanisms that were implemented in (...).

- Indicate the reason why that entity carried out two (...) on such close dates (...). In the event of having carried out another or others (...) from February 1, 2021 to the present, provide them dated and signed.

- (...).

- Provide, dated and signed, the following documents in the version in force at that banking entity as of February 1, 2021:

(...).

(...).

(...). (In this case, provide, if applicable, the document that on this same matter was in force as of February 1, 2021).

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/121

2. On June 13, 2023, a request from CaixaBank for an extension of the deadline granted for the practice of evidence I by 5 additional business days was received, and the requested extension was granted.

3. On June 28, 2023, a letter from CaixaBank was received in response to the evidence request of June 7, 2023, accompanied by various documentation.

Practice of evidence II:

1. After examining the documentation submitted by CaixaBank, on July 10, 2023, CaixaBank was requested to send the following information and documentation:

- A copy of the complaint filed by Mr. A.A.A. (the claimant) at the CaixaBank customer service office on October 31, 2021, registered (...), along with any documentation that may have accompanied it.
- In relation to the DOCUMENTS (...), a dated and signed certificate indicating the date (...).
- A dated and signed certificate indicating the data(s) modified by Mr. A.A.A. (the claimant) on February 1, 2021, when updating contact information.
- In the letter from that financial entity dated June 28, 2023, it is indicated that ***DATE.1 (...).
- In the opening letter of the evidence period, it was required:

“(…)”

(…):

“First of all, it is necessary to point out the following:

i) (...)

ii) (...).

(…).”

In the letter dated December 13, 2022, prepared by that banking entity in response to a request for information from the inspector, it was stated:

(the underlining is ours)

“ACTION PLAN AND RISK ELIMINATION

(…).”

On the other hand, in the letter of allegations to the initiation agreement of February 20, 2023, that financial entity highlighted: (the underlining is ours).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/121

“(…).”

In light of the excerpts from the writings of that financial entity that have just been reproduced, it is requested that a dated and signed document be submitted clarifying (...).

- In the document dated December 13, 2022, prepared by that financial entity in response to an information request from the inspector, the following information appears:

“(…).”

In view of the documentation sent by that financial entity, clarify whether the information (...).

Also, clarify whether the information (...).

2. On July 14, 2023, a request from CaixaBank for an extension of the deadline granted for the execution of Test II by an additional 3 business days was received.

On that same date, a document was sent to the defendant party communicating that it was agreed not to extend the deadline for providing the required documentation and information in the execution of Test II by an additional 3 business days, given that with this additional deadline, the 30-day period for the opening of the testing period contemplated in Article 77.2 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations would be exceeded.

3. On July 18, 2023, a document from CaixaBank in response to the test request of July 10, 2023, accompanied by various documentation, was received.

Execution of Test III:

1. Examining the content of the document (...), on July 12, 2023, CaixaBank was requested to send a dated and signed certificate attesting to:

- (...).

- (...).

2. On July 14, 2023, a request from CaixaBank for an extension of the deadline granted for the execution of Test III by an additional 1 business day was received.

On that same date, a document was sent to the defendant party granting the requested deadline extension.

3. On July 18, 2023, a document from CaixaBank in response to the test request of July 12, 2023, was received.

b. Before the AEPD Inspection:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/121

1. On July 17, 2023, an internal note was sent to the Inspection Coordinator indicating the following:

“(…) On June 28, 2023, a document submitted by CAIXABANK, S.A. was received, a copy of which is attached, (…):

“(…)”

It is requested that, in view of the information provided by CAIXABANK, S.A. in this file, an urgent report be prepared regarding the probability that (…).

It is also requested that it indicate whether this probability calculation could be applied to the number or (…).”

2. On July 18, 2023, a report from the Inspector requested by the instructor in the context of the execution of the test was received, the content of which is reproduced below:

“REPORT REQUESTED BY THE INSTRUCTOR OF PS/00020/2023 IN THE CONTEXT OF THE EXECUTION OF THE TEST

BACKGROUND

Date of entry of the complaint: May 10, 2022

Claimant: A.A.A. (hereinafter, the claiming party)

Defendant: CAIXABANK, S.A. (hereinafter, the defendant party)

Facts according to the statements of the claiming party:

The claiming party is a client of the defendant party. They state that, (…), specifically, (…) a document (dated February 1, 2021) related to a transfer from a third party (which contains numerous personal data of that third party, such as ID number, postal address, bank account number, etc.) made to another unknown person appears.

INVESTIGATED ENTITIES

During the present proceedings, the following entities have been investigated:

CAIXABANK, S.A. with NIF A08663619 located at ADDRESS.1 VALÈNCIA (VALENCIA)

RESULT OF THE INVESTIGATION PROCEEDINGS

- Regarding the (…), the representatives of the entity inform that (…)

They also provide that at the moment (…), this implies (…)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/121

(…)

- (…):

(…).

(…).

It should be noted that the probability values give the average value, which implies that, although the system has (…).

(…).

CONCLUSIONS

(…).

B.B.B.

INSPECTOR “

3. On July 18, 2023, a diligence was prepared that reproduces, for evidentiary purposes, the report of the same date prepared by the inspector, the content of which has been reflected in the previous section.

EIGHTH: PROPOSAL FOR RESOLUTION

On September 19, 2023, a proposal for resolution was made, proposing:

“FIRST: That the Director of the Spanish Agency for Data Protection sanction CAIXABANK, S.A., with NIF A08663619, for an infringement of Article 5.1.f) of the GDPR classified in Article 83.5.a) and qualified as very serious for the purposes of prescription in Article 72.1 a) of the LOPDGDD, with a fine of €2,000,000 (two million euros).

SECOND: That the Director of the Spanish Agency for Data Protection sanction the entity CAIXABANK, S.A., for an infringement of Article 25 of the GDPR, classified in Article 83.4 a) and qualified as serious for the purposes of prescription in Article 73 d) of the LOPDGDD, with a fine of €1,500,000 (one million five hundred thousand euros).

THIRD: That the Director of the Spanish Agency for Data Protection sanction the entity CAIXABANK, S.A., for an infringement of Article 32 of the GDPR, classified in Article 83.4 a) and qualified as serious for the purposes of prescription in Article 73 f) of the LOPDGDD, with a fine of €1,500,000 (one million five hundred thousand euros).

FOURTH: That the Director of the Spanish Agency for Data Protection require CAIXABANK, S.A., to implement the necessary corrective measures to align its actions with the regulations in accordance with Article 58.2.d) of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/121

of personal data protection within the timeframe determined, as well as to inform this Agency within the same timeframe about the measures adopted.”

NINTH:

ALLEGATIONS TO THE PROPOSAL FOR RESOLUTION

Notified of the proposal for resolution in accordance with the rules established in the LPACAP, the respondent party submitted a written statement of allegations to the proposal for resolution on October 6, 2023, in which, in summary, it states the following:

CaixaBank reiterates all the allegations made regarding the initiation agreement in its written statement of February 20, 2023.

In the opinion of the banking entity, the proposal for resolution reiterates what had already been argued by the AEPD in the initiation agreement, an argument they consider erroneous, without addressing what CaixaBank has alleged.

CaixaBank outlines the reasons why, in its opinion, the case should be archived:

I. The banking entity believes that the proposal for resolution makes a series of inaccurate considerations:

1. The respondent party considers that this proposal is based on a report prepared by the Inspector on July 18, 2023, submitted along with the proposal, in which the probability of the occurrence of the events that led to the personal data breach analyzed in this file is calculated.

In relation to this report, CaixaBank considers that:

a. The methodology used lacks adequate scientific rigor.

b. It does not take into account that (...).

c. The data used (...) (date on which the personal data breach subject to the file occurred), (...). On that date, (...) and the banking entity claims that a personal data breach could not have occurred.

d. The calculated probability would be (...), not the actual one.

2. The Proposal for resolution overlooks that the (...) was, in CaixaBank's opinion, a sufficient measure to prevent the personal data breach from occurring again.

3. The AEPD establishes a concept of availability breach that does not correspond with that set by the

AEPD itself and the competent bodies within the framework of the European Union.

In CaixaBank's opinion, it equates a breach of data availability with what is merely a lack of availability in a service provided voluntarily to its clients ((...)).

It also states that the complainant was never limited in their ability to access such data.

4. The AEPD equates the request for modification of contact data by the complainant with the right to rectification, but at the same time considers that the fact that the interested party does not receive confirmation of the modification made until (...) constitutes a violation of data protection regulations.

Despite the fact that such regulations establish a one-month period to respond to the rectification request.

5. The AEPD indicates, in a novel manner in the proposal for resolution, that CaixaBank lacks an adequate procedure for addressing its clients' complaints regarding data protection, despite having only one case in which this procedure was not followed and not having required the banking entity about the existence of such a procedure. In the opinion of the banking entity, the doctrine established in the National Court ruling of December 23, 2022, would have been violated by turning what occurred in a specific case into a systematic violation.

II. CaixaBank insists that the proposal violates the principle of non bis in idem.

III. The complainant again emphasizes that, in their opinion, there is a medial concurrence among the three infractions attributed to the banking entity.

In this regard, it highlights that the proposal makes a reasoning that leads to the consideration that the principles of sanctioning law and the doctrine of the Constitutional Court regarding the application of the guarantees of criminal law to administrative sanctioning law do not apply in this case, simply because these principles are not expressly included in data protection regulations.

Furthermore, CaixaBank asserts that the AEPD establishes a doctrine contrary to that previously adopted in other resolutions in which it had recognized the concurrence of medial concurrence.

IV. In the opinion of the banking entity, none of the three infractions contemplated in the proposal for resolution are in accordance with the law.

Article 25 of the GDPR:

CaixaBank claims that it fully respects the principle of privacy by design in all actions involving the processing of personal data, as well as when handling complaints directed to it by its clients or any interested party.

It considers that the measures it uses (...) are aimed at ensuring, from the design stage, the security of data, the integrity of documents, and avoiding risks to the rights and freedoms of the interested parties. It emphasizes that the measures subsequently adopted by CaixaBank only represent the assumption of the principle of privacy by design and the reinforcement of the guarantees of the rights of the interested parties.

It denies that responsibility can be attributed to it based on alleged "doubts" regarding these measures, as this would violate the principle of presumption of innocence.

Article 32 GDPR:

It considers that the reasoning regarding the supposed absence of security measures is based on the calculation made by the Inspector on July 18, 2023.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/121

Article 5.1 f):

In the opinion of the banking entity, the alleged violation of the principle of confidentiality arises solely and exclusively from the absence of security measures; it would merely be an unintended result of CaixaBank adopting the appropriate security measures. The claiming party believes that this route would be used to disregard the doctrine of the Supreme Court, which considers the obligation of security measures as an obligation of means and not of result.

V. CaixaBank claims to have adopted the appropriate technical and organizational measures to prevent the recurrence of the personal data breach in the future.

Furthermore, it emphasizes that the proposed resolution refers to the necessary adoption of corrective measures on its part without specifying what those measures are, which implies a clear situation of defenselessness for the banking entity.

VI. The responding party insists again on the violation of the principle of proportionality.

It considers that circumstances apply which, in its opinion, do not occur in the analyzed case.

Moreover, it estimates that these circumstances are affected by the calculation made by the Inspector. In the opinion of the responding party, the proposal does not take into account that the possibility of the incident recurring has been completely impossible for almost two years before the initiation of the sanctioning procedure and even before the claim was made by the interested party.

In light of all that has been acted upon by the Spanish Agency for Data Protection in the present procedure, the following facts are considered proven,

PROVEN FACTS

INDEX OF PROVEN FACTS

For the purpose of facilitating the reading of the proven facts recorded in the resolution, we will indicate that:

- From the first proven fact to the twenty-eighth proven fact, the proven facts related to the claim presented by the claimant are recorded.
- From the twenty-ninth proven fact to the forty-first proven fact, the proven facts related to (...) are recorded.
- From the forty-second proven fact to the forty-fifth proven fact, the proven facts related to (...) are recorded.
- From the forty-sixth proven fact to the fiftieth proven fact, the proven facts related to (...) are recorded.
- The fifty-first proven fact refers to the (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/121

- From the fifty-second proven fact to the fifty-third proven fact, the proven facts referred to (...) are recorded.

FIRST:

Mr. A.A.A. (the claimant), a client of CaixaBank, updated his contact details on February 1, 2021, the date on which the personal data breach occurred. (...)

SECOND:

The update of contact details carried out by Mr. A.A.A. on February 1, 2021, consisted of:

- Cancelling the Phone (...) ***PHONE.1
- Registering the Phone (...) ***PHONE.2
- Registering the Phone (...) ***PHONE.3

In the CaixaBank certificate dated July 18, 2023, it is indicated:

“(...)”

THIRD:

The update of contact details was carried out.

However, (...)

In this regard, CaixaBank in its letter dated December 13, 2022, states:

“(...) the documents (...)”

FOURTH:

(...).

FIFTH:

On the same date (February 1, 2021), when the personal data breach occurred, Mr. C.C.C. made a transfer, (...) directed to a third party, a client of another banking entity. This transfer was executed correctly.

In the CaixaBank letter dated December 13, 2022, it is indicated:

"indeed it was done (...). The operation was correct."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/121

SIXTH:

In the transfer receipt made by D. C.C.C., which the claimant was able to view, numerous data were included:

- Name of the banking entity (...).
- Date on which the transfer issuance request was made: (...)
- Time at which the banking operation was carried out: (...)
- Reference number of the banking operation.
- Name, surname, NIF of the transferor, as well as their address.
- IBAN of the current account from which the transfer was made.
- (...) or banking code.
- Amount of the transfer.
- Concept for which the transfer was made.
- Name and Surname of the beneficiary of the transfer.
- IBAN of the beneficiary's bank account.
- (...) or banking code.
- Data of the destination entity: (...)
- Electronic evidence of the authorization made through (...)

Consequently, the claimant was able to access personal data (name and surname, both of the transferor and the beneficiary of the transfer, NIF and address of the transferor, IBAN of the bank accounts of origin and destination of the transfer). As well as multiple data related to the banking operation carried out.

SEVENTH:

CaixaBank emphasizes that, despite the breach of personal data, D. C.C.C. (transferor of the transfer) was able to view (...) the transfer receipt that he had made from the very beginning.

In the document dated June 28, 2023, prepared in response to the request for evidence I, CaixaBank indicates:

"(...)."

EIGHTH:

On the day both banking operations took place and the personal data breach occurred (February 1, 2021), CaixaBank carried out (...).

In the CaixaBank certificate dated July 18, 2023, prepared in response to the request for evidence III, the following is indicated:

"1. (...)."

NINTH:

The claimant had available in the section called "(...)" (...) the receipt of the transfer made by D. C.C.C. to a third party, a client of another banking entity, being able to access the content of that document from the (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/121

The sixth proven fact reflects what personal data appeared in that receipt.

TENTH:

The claimant did not have available in the section called (...) the receipt of the update of contact data

made until the (...).

ELEVENTH:

On October 31, 2021, the claimant filed a complaint with the customer service office of CaixaBank, which was registered with the number ***REGISTRO.1 with the following text:

“Hello I have a document that appears in my (...) on 01/02/2021 confidential of another Caixa client showing all the personal and confidential information of the people due to a transfer I request a complaint because it is a serious disclosure of personal information and as compensation I request the value of the transfer that appears in this document ***CANTIDAD € Regards”

- The receipt of the transfer dated February 1, 2021 made by D. C.C.C., which also accompanied the complaint forwarded to the AEPD by the Bank of Spain, the content of which has been reflected in the fourteenth proven fact.

- (...).

(...)”

(...)

In response to the request for evidence II, CaixaBank has provided, in addition to the documentation just referenced, a screenshot containing the following information (DOCUMENT NUMBER 1):

(...).

In the field designated to reflect the complaint, preliminary information appears:

(...)

TWELFTH:

On November 2, 2021, at 14:32, the claimant received, at his email address, the following automatic message from the customer service office of CaixaBank.

Message title

(...)

Message text:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/121

“(...)”

(...)

THIRTEENTH:

The claimant received a response to the complaint dated October 31, presented through a letter from CaixaBank dated November 10, 2021, (...), in which reference was made to an alleged disagreement with some receipts charged to the claimant's bank account that were not authorized:

In said letter, it was stated:

“Response to your complaint or claim

Ref. No. Claim: ***REGISTRO.1 [Coinciding with the number assigned to the claim presented by the claimant at CaixaBank reflected in the twelfth proven fact].

Dear Sir:

We are writing to you in response to your claim, which expresses disagreement with some receipts charged to your account and not authorized.

First of all, we wish to explain that at CaixaBank we strive to provide you with the necessary means to assist you with the utmost professionalism, and for this we invest all our efforts to achieve this objective. Therefore, we regret that the perception of the service received has not met your expectations. We confirm that, in any case, your opinion is of great value to CaixaBank as it will undoubtedly allow the entity to improve the quality service it wishes to offer its clients.

In this regard, once the appropriate checks have been carried out, we must inform you that CaixaBank is limited to charging the receipts according to what is indicated by the issuer of the payment order.

Therefore, you should contact the issuing company of the receipt to request the corresponding direct debit order.

Thus, we understand that your claim has been satisfied and we consider our action in this matter

concluded, remaining at your disposal for any questions you may have.

Hoping to have provided you with a useful response and information, we wish to express our gratitude for the trust placed in CaixaBank and for the opportunity you give us to improve the quality of our service.

In case of disagreement with this decision, you may submit your claim to the Complaints Service of the Bank of Spain, by means of a letter sent to the postal address (...) or electronically (...)

Yours sincerely,"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/121

FOURTEENTH:

On February 10, 2022, at 10:42:29, a complaint was received in the Conduct of Entities Department of the Bank of Spain presented by Mr. A.A.A. in which he indicated:

"CaixaBank does not respect data confidentiality regulations

I have a document with personal data of another person that has nothing to do with me in this transfer document there is information such as NIE bank account number...

This document appears (...) on February 1, 2021

I claim the value of the transfer that appears for serious breach of this regulation

when I have made a complaint to Caixa as always they do not really respond to the stated problem"

He attached to this complaint various documents, among them:

1. The proof of the transfer made by Mr. C.C.C., the content of which has been reflected in the sixth proven fact.
2. The automatic response sent by CaixaBank on November 2, 2021, upon receiving the complaint from Mr. A.A.A. dated October 31, 2021, reproduced in the twelfth proven fact.
3. The response to the complaint or claim from CaixaBank dated November 10, 2021, derived from the claim presented on October 31, 2021, reflected in the thirteenth proven fact.

FIFTEENTH:

On May 5, 2022, the Conduct of Entities Department of the Bank of Spain forwarded to this Agency the complaint dated February 10, 2022, presented by Mr. A.A.A., considering that its subject matter essentially affected activities related to data protection.

SIXTEENTH:

On June 7, 2022, the AEPD forwarded the complaint requesting information from CaixaBank. The acknowledgment of receipt related to this transfer confirms that CaixaBank accepted the notification on June 8, 2022.

SEVENTEENTH:

(...).

On one hand, in CaixaBank's letter dated June 28, 2023, prepared in response to the evidence practice I, it is indicated:

"(...)."

On the other hand, along with said letter of June 28, 2023, CaixaBank has provided an email titled (...) with the following text:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/121

"(...)

(...)"

EIGHTEENTH:

On July 22, 2022, CaixaBank sent a letter to the claimant in order to respond to the complaint he had

submitted on October 31, 2021.

Said letter shows that the banking entity at that time was trying to determine the cause that had allowed Mr. A.A.A. to access the proof of a transfer that another CaixaBank client had made to a third client of another banking entity.

The letter states that on that date (July 22, 2022) the proof of the transfer made by Mr. C.C.C. through the (...) was no longer accessible.

Content of the letter addressed to the claimant:

“(…):

(…)”

On the same date, July 22, 2022, CaixaBank sent another letter to this Agency, the content of which is very similar to that sent to the claimant, which is partially reproduced:

“(…):

(…)”

NINETEENTH:

As of July 22, 2022, Mr. A.A.A., the claimant, did not have at his disposal (...) the proof of the update of contact data that he had made on February 1, 2021.

TWENTIETH:

On August 4, 2022, CaixaBank (almost two months after having become aware of the personal data breach) prepared a first report on the personal data breach subject to the complaint. Indicating that the personal data breach:

1. (...)

2. (...),

3. (...).

In said report, among other aspects, it is indicated:

“(…)

(…)”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/121

TWENTY-FIRST:

On August 12, 2022, the claimant did not yet have the proof of the (...) that had been carried out on February 1, 2021, the date on which the personal data breach occurred.

On that same date, August 12, 2022, a letter from the claimant was received by the AEPD, sending a copy of a letter of that same date addressed to the customer service of CaixaBank with the following text:

“Hello

I have received the response to this complaint

First, you acknowledge the error and I am glad about that

But there is still an error that compromises the data protection of Caixa customers and if I have received this document, who has received the document of (...) with my banking and personal data?

Second, you say that it is a specific error

But the document was generated on February 1, 2021

I made the complaint to the Bank of Spain on February 10, 2022, and as of July 22, 2022, from that day this document does not appear in any documents unrelated to the operations carried out

So due to a specific error of disclosure of protected data, it has remained for almost 1 year and 5 months with the possibility of accessing this document

Third, I quote: on February 1, 2021, I carried out the operation: (...) in this case, why can't I access this document related to this operation with the correct corresponding document

When I verify (...)

I attach a photo of the period of this operation that I currently have and the one I took before simply (...)

But if I made an operation on this date, it should appear (...) and I ask that you send me the document related to this (...)

(...) to say that the problem is fixed when you need to rectify and provide me with the correct document that corresponds to this operation

That means one thing: the problem is not fixed and it is easier to do (...) if that is how you analyze the problem (...)

Waiting for a quick response with financial compensation”

TWENTY-SECOND:

On ***DATE.2, the claimant had available (...) the document that allowed him to verify the update of contact data that had been carried out on February 1, 2021, the date on which the personal data breach occurred.

CaixaBank in its letter of June 28, 2023, prepared in response to the practice of evidence I dated June 7, 2023, indicates:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/121

“(...)”

TWENTY-THIRD:

On October 4, 2022, CaixaBank considered that a (...) had occurred.

In this regard, the AEPD received CaixaBank's response to the information request from the Inspector dated September 23, 2022, in which it indicates, among other aspects, the following:

“a) (...):

(...).

b) (...).”

TWENTY-FOURTH:

(...) of the personal data breach.

(...). This financial entity highlights in its letter of June 28, 2023, in response to the practice of evidence I:

“(...)”

TWENTY-FIFTH:

On November 21, 2022, the inspector sent CaixaBank a second information request, in which, among other issues, it required:

“It is required that you communicate to this Agency

- A complete report of the analysis carried out on the incident.

- A detailed explanation of (...). Documentary evidence must be provided.

- Description (...). Documentary evidence must be provided.”

TWENTY-SIXTH:

On December 12, 2022, CaixaBank carried out (...) (prepared one day before responding to the second information request from the Inspector).

Indicating that the personal data breach:

1. (...)

2. (...)

3. (...).

(...):

“(...)”

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/121

TWENTY-SEVENTH:

On December 13, 2022, CaixaBank informed this Agency that the personal data breach, which it only qualified as a loss of confidentiality, had occurred (...).

(...). Below are two excerpts from the letter prepared by CaixaBank on December 13, 2022, relating to this issue:

(...)

In the letter from CaixaBank dated December 13, 2022, it is indicated:

(...)

Subsequently, in the letter of allegations to the initiation agreement dated February 20, 2023, prepared by CaixaBank in relation to this issue, it was highlighted:

(...)

TWENTY-EIGHTH:

As of December 13, 2022 (...):

In the letter from CaixaBank dated December 13, 2022, it is highlighted:

(...)

TWENTY-NINTH:

Both in the letter from CaixaBank dated December 13, 2022, and in the letter from CaixaBank of allegations to the initiation agreement dated February 20, 2023, CaixaBank stated that the action taken as a result of the personal data breach, as a solution and measure of system robustness, was (...).

Below is a paragraph from the letter from CaixaBank dated December 13, 2022:

(...)

Additionally, the section titled (...) from the letter from CaixaBank dated December 13, 2022, is reproduced:

(...)

In relation to this issue, in DOCUMENT NUMBER 7, which accompanies the letter of allegations to the initiation agreement from CaixaBank dated February 20, 2023, it is indicated:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/121

(...)

THIRTIETH:

CaixaBank states that at the time the personal data breach occurred, (...)

In the letter dated December 13, 2022, it is indicated:

(...)

THIRTY-FIRST:

(...)

In the letter from CaixaBank dated June 28, 2023, prepared in response to the practice of evidence I, it is indicated:

(...)

THIRTY-SECOND:

(...)

In the letter dated June 28, 2023, prepared in connection with the practice of evidence I, it is indicated:

(...)

THIRTY-THIRD:

CaixaBank states that (...).

In this regard, in the letter dated June 28, 2023, in response to the practice of evidence I, it is indicated:

(...)

THIRTY-FOURTH:

(...).

(...).

(...)

THIRTY-FIFTH:

CaixaBank states that, (...).

In this regard, in the letter dated July 18, 2023, prepared in response to the practice of evidence II, it is highlighted:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/121

(...)

THIRTY-SIXTH:

(...).

In relation to this matter, in the document dated July 18, 2023, prepared in response to the evidence practice II, it is stated:

(...):

(...),

THIRTY-SEVENTH:

(...):

1. (...).

2. (...).

3. (...).

Three paragraphs from the document dated July 18, 2023, prepared in response to the evidence practice II are reproduced.

(...)

THIRTY-EIGHTH:

The inspector estimates (...).

In this regard, the preliminary investigation report dated January 18, 2023 states:

“The way to resolve the incident, (...).

THIRTY-NINTH:

(...):

1. (...).

2. (...).

3. (...).

Three paragraphs from the document dated July 18, 2023, prepared in response to the evidence practice II are reproduced.

(...):

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/121

▪ (...).

(...).

FORTIETH:

(...).

The following paragraphs from the document dated July 18, 2023, prepared in response to the evidence practice II are reproduced.

(...)

FORTY-FIRST:

CaixaBank describes in its document dated December 13, 2022

(...)

(...)

FORTY-SECOND:

To keep the supporting documentation of the banking operations (...)

(...)

In relation to this matter, the document from CaixaBank dated December 13, 2022 reflects:

(...)

(...)

(...).

In relation to this matter, DOCUMENT NUMBER 7, which accompanies the allegations document regarding the initiation agreement dated February 20, 2023, CaixaBank highlights:

(...)

(...)

FORTY-THIRD:

As of December 13, 2022, in CaixaBank (...)

In the document from CaixaBank dated December 13, 2023, it is indicated:

(...)

(...).

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/121

(...)

Likewise, in the document from CaixaBank dated June 28, 2023, prepared in response to the evidence practice I, it is indicated:

“(...).”

FORTY-FOURTH:

The inspector considers that (...).

The preliminary investigation report dated January 18, 2023 indicates:

“(...).”

FORTY-FIFTH:

(...).

(...):

In the document from CaixaBank dated June 28, 2023, prepared in response to the evidence practice I, it is indicated:

“(...).

(...).”

FORTY-SIXTH:

As of December 13, 2022, CaixaBank considered that the probability of (...) or the recurrence of the case (personal data breach) was (...).

In the document of that same date, CaixaBank indicates:

“(...).

(...)”

It also states:

“(...

(...)”

FORTY-SEVENTH:

The inspector in the preliminary investigation report dated January 18, 2023 highlighted that, given the

number of clients of CaixaBank and the number of operations carried out in that banking entity, (...).
In this regard, the aforementioned report states:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

41/121

“From the analysis of the information provided, it follows that the origin of the incident (...).

FORTY-EIGHTH:

CaixaBank states that (...).

(...).

(...):

“(...).”

FORTY-NINTH:

On July 17, 2023, a request was made for a report to be prepared by the AEPD Inspection in the context of the evidence practice:

In the internal note of the same date, it was indicated:

“(...):

(...).”

FIFTIETH:

In response to the request for a report in the context of the evidence practice, reflected in the proven fact forty-ninth, the inspector prepared a report, included in the diligence dated July 18, 2023, in which he concluded that, (...),

Part of the content of that report is reproduced:

“• Regarding the frequency with which this error may occur, the representatives of the entity report that
“(...).”

FIFTY-FIRST:

CaixaBank has certified that (...) in that financial entity. This data has been obtained from the (...), submitted on June 28, 2023, in response to the evidence practice I.

FIFTY-SECOND:

On June 28, 2023, CaixaBank certifies the dates on which security risk analyses have been carried out in the (...) (related to the personal data breach subject to the complaint):

“(...).”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/121

FIFTY-THIRD:

In relation to the reviews (...), according to the information provided by CaixaBank in its letter dated June 28, 2023, it can be stated that:

As of February 1, 2021, the date on which the personal data breach occurred, the (...) was not in effect.

On that date (February 1, 2021), the (...) was also not in effect.

(...).

(...).

In relation to this issue, in CaixaBank's letter dated June 28, 2023, prepared in response to the evidence practice I, it is indicated:

“(...).”

LEGAL GROUNDS

I Competence

According to the powers granted to each supervisory authority by Article 58.2 of Regulation (EU)

2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II Path of the complaint

Before proceeding to analyze the allegations made by CaixaBank, it is deemed necessary to examine the path of the complaint. Referring to other actions, whether by the respondent party or the AEPD, that allow understanding the personal data breach that has led to this sanctioning procedure:

01/02/21 The complainant updated their contact details.

They carried out this operation (...).

On the same day, Mr. C.C.C., another CaixaBank client, made a transfer (...), directed to a third party, a client of another banking entity.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/121

(...).

(...).

(...).

(...).

As a result, the complainant had (...), which contained numerous personal data, both of the transferor and the beneficiary, as well as other data related to the financial operation carried out. However, they did not have the (...) available on February 1, 2021.

20/02/21 (...).

The deactivation occurred (...).

21/06/21 CaixaBank carried out (...).

31/10/21 The complainant filed a complaint with CaixaBank's customer service office. (...).

02/11/21 The complainant received at their email address (...).

10/11/21 CaixaBank sent (...).

09/02/22 CaixaBank carried out (...).

10/02/22 (When a year had already passed since the personal data breach occurred) The complainant filed a complaint, very similar to the one already raised with CaixaBank on (...), with the Conduct Department of the Bank of Spain.

05/05/22 The Conduct Department forwarded the complaint to the AEPD, with entry in the General Registry of the Agency on 10/05/22.

07/06/22 The AEPD forwarded the transfer of the complaint and a request for information to CaixaBank, which received this document on June 8, 2022.

08/06/22 Date on which CaixaBank and its (...).

22/07/22 CaixaBank sent to the (...).

(...).

04/08/22 CaixaBank prepared (...).

□

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/121

☐

(...).

☐

(...).

☐

(...).

10/08/22 Admission of the complaint for processing.

12/08/22 The complainant sent an email to CaixaBank's Customer Service and forwarded a copy of it to the AEPD.

In this letter, they highlighted that (...) had been able to access the proof of the transfer made by another CaixaBank client. They also requested that the proof of the data update they had made on February 1, 2021, be sent to them.

23/09/22 First request for information made by the Inspector to CaixaBank, informing the AEPD of the results of the analysis carried out on the incident and whether it had been detected that there could be a security breach affecting other clients.

04/10/22 Letter from CaixaBank responding to the Inspector's request for information indicating that it was (...).

05/10/22 CaixaBank (...).

21/11/22 Second request for information made by the Inspector, in which it is requested:

“

☐

(...)

☐

(...).

12/12/22 CaixaBank prepared a second report on the personal data breach.

It considered that the cause was a technical error: “(…).”

In the section titled “Action Plan,” it is indicated:

☐

(...).

☐

(...).

☐

(...).

13/12/22 Letter from CaixaBank responding to the second request for information made by the Inspector, highlighting that “(…).”

10/05/23 CaixaBank began to use (...).

16/05/23 CaixaBank carried out (...).

01/06/23 At CaixaBank (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/121

07/06/23 In the evidence practice I, information is requested regarding various issues, among them: “(…).”

20/06/23 The claimant had (...) the proof of the update of contact details that had been carried out on February 1, 2021.

17/07/23 The Inspector prepared a report, based on the average operations per second as of June 1, 2023.

From the content of this iteration, several conclusions can be drawn:

1. The personal data breach that occurred on February 1, 2021, went unnoticed by CaixaBank for an extended period of time.

(...).

2. The proof of the transfer made by Mr. C.C.C. (...).

3. Once the personal data breach was detected by CaixaBank, (...). This report highlighted that the breach occurred as a result of (...). The banking entity carried out (...).

3. (...).

Despite determining this definitive cause, (...).

4. The claimant did not have available (...) the proof of the update of data that had been carried out on February 1, 2021, until ***DATE.2 (...). (...) the evidence practice I, sent by the AEPD on June 7, 2023, (...).

III

Allegations to the initiation agreement and to the resolution proposal

Throughout the legal grounds of this resolution, responses will be provided to the allegations made by CaixaBank both to the initiation agreement and to the resolution proposal.

As reflected in this resolution, initially, the actions of this AEPD were aimed at determining the circumstances that led to a personal data breach, which allowed a CaixaBank customer to access the personal data of two individuals, who appeared on the proof of a transfer made by another customer of that banking entity.

However, through the preliminary investigative actions and linked to the complaint filed, and as has been demonstrated throughout this procedure, the AEPD has become aware of deficiencies in the procedure that affected both the security measures adopted by the entity and design aspects that would violate privacy by design.

Despite the banking entity insisting in its allegations that everything boils down to a single complaint from one of its customers, this complaint has brought to light various issues related both to Article 32 of the GDPR and to Article 25 of that Regulation, procedural deficiencies that are considered sanctionable in themselves.

On the other hand, it is worth highlighting that the written allegations to the resolution proposal have not refuted the proven facts that appeared in that proposal and that have been reproduced in this resolution. It only questions the proven fact thirty-second, considering that, while what is indicated therein may be considered true, an interpretation is made therein that it considers incomplete.

Response to the alleged violation of the principle of non bis in idem:

CaixaBank alleges that the content of the initiation agreement would imply a supposed violation of the principle of non bis in idem (in its opinion, there could even be a case of non ter in idem), reiterating this allegation in its written allegations to the resolution proposal.

Firstly, Articles 5.1 f), 32, and 25 are classified differently in the GDPR. Likewise, they are classified differently, for the purposes of prescription, in the LOPDGDD and each of them enjoys its own entity.

Regarding the supposed concurrence of Articles 5.1 f) and 32 of the GDPR:

In its written allegations to the initiation agreement, CaixaBank states:

“(...) the Initiation Agreement imposes two differentiated sanctions, for lacking security measures and because a breach of confidentiality has occurred due to lacking such measures, and, as it claims, which will later be disproven, availability of the data.

Thus, the AEPD considers the same facts constitutive of an infringement of a principle provided for in Article 5.1 of the GDPR and its specification or materialization, carried out, in this case, in Article 32 of the GDPR. It thus sanctions not having measures and a breach for not having measures, which implies a sanctioning reiteration prohibited by administrative sanctioning law.

And if the reasoning maintained here were to be followed, any violation of a provision of the GDPR would imply the commission not only of the infringement of that provision but also of the principle of data protection from which the violated norm originated. Thus, for example, the violation of Articles 6 to 10 of the GDPR would also imply a violation of the principle of lawfulness or the violation of Articles 13 and 14 a violation of the principle of transparency, which, however, is not reflected in the resolutions of the AEPD that, nevertheless, do not hesitate to simultaneously consider Articles 5.1 f) and 32 of that legal text as violated.”

C/ Jorge Juan, 6

www.aepd.es

In relation to the allegations that have just been reproduced, it is necessary to bring to attention the difference between the violation of Article 5.1(f) and Article 32 of the GDPR, the different classifications in separate sections of Article 83 of the GDPR, and the different qualification of both for the purposes of prescription in the LOPDGDD.

Article 5.1(f) of the GDPR is violated when there is a loss of confidentiality or integrity of personal data, which may or may not occur due to the absence or deficiency of security measures.

This principle merely determines the channel through which the maintenance of confidentiality and integrity can be achieved when it explicitly states "through the application of appropriate technical and organizational measures," which are not strictly security measures.

There are multiple technical or organizational measures, which are not security-related, that the data controller can implement as a means to ensure this principle.

However, Article 32 of the GDPR encompasses the obligation to implement appropriate technical and organizational security measures to ensure a level of security appropriate to the risk. Security measures. Only security measures.

Moreover, its objective is to ensure a level of security appropriate to the risk, whereas in the case of Article 5.1(f) of the GDPR, confidentiality and integrity must be guaranteed. As can be observed, the two articles pursue different aims, although they may be related.

Delving directly into the examination of non bis in idem, the Judgment of the National Court of July 23, 2021 (rec. 1/2017) states that,

"(...) According to the legislation and jurisprudence presented, the principle of non bis in idem prevents punishing the same subject twice for the same act based on the same grounds, understood as the same legal interest protected by the sanctioning norms in question. Indeed, when there is a triple identity of subject, act, and grounds, the accumulation of sanctions creates a penalty foreign to the proportionality assessment carried out by the legislator and materializes the imposition of a sanction not legally provided for, which also violates the principle of proportionality.

However, for "bis in idem" to be applicable, there must be a triple identity between the compared terms: objective (same facts), subjective (against the same subjects), and causal (for the same grounds or reason for punishment):

- a) The subjective identity implies that the affected subject must be the same, regardless of the nature or judicial or administrative authority that judges and irrespective of who the accuser is or the specific body that has resolved, or whether it is judged alone or in conjunction with other affected parties.
- b) The factual identity implies that the judged facts must be the same, and it excludes cases of real concurrence of infringements where there is not a single unlawful act but several.
- c) The identity of grounds or causal identity implies that the sanctioning measures cannot coincide if they respond to the same nature, that is, if they par...

"they share the same teleological foundation, which occurs between penal and administrative sanctions, but not between punitive and merely coercive measures."

Taking into account the previously stated in the sanctioning procedure under review, the principle of non bis in idem has not been violated, since, although broadly understood, the facts are detected as a consequence of a personal data breach, the infringement of Article 5.1.f) of the GDPR is specifically related to a clear loss of confidentiality and availability, while the infringement of Article 32 of the GDPR pertains to the deficiency of the security measures (only security) detected, which are present independently of the personal data breach. In fact, if these security measures that CaixaBank had implemented had been detected by the AEPD without the loss of confidentiality occurring, it would have only been sanctioned under Article 32 of the GDPR.

As we have indicated, Article 5.1.f) of the GDPR sanctions a loss of confidentiality and availability, while Article 32 of the GDPR addresses the deficiency of the security measures implemented by the data controller. We add that deficient security measures violate the GDPR, regardless of whether a personal data breach has occurred.

Regarding the alleged concurrence of Articles 25 and 32 of the GDPR:

Article 25.1 of the GDPR states:

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing poses to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of data subjects.”

1. As can be observed, this article starts from the need to consider a series of elements:

- State of the art
- Cost of implementation
- Nature, scope, context, and purposes of the processing
- Risks posed by the processing to the rights and freedoms of natural persons.

2. It imposes an obligation on the controller, who determines the purposes and means of the processing, giving, in this case, special relevance to the means.

3. The controller must apply, both when determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures (for example, pseudonymization), designed to effectively apply the principles of data protection and integrate the necessary safeguards into the processing.

4. In doing so, it pursues a dual purpose:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/121

- Comply with the requirements of the GDPR
- Protect the rights of data subjects.

For its part, Recital 78 of the GDPR provides:

“78) The protection of the rights and freedoms of natural persons with regard to the processing of personal data requires the adoption of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation. In order to demonstrate compliance with this Regulation, the data controller must adopt internal policies and implement measures that comply in particular with the principles of data protection by design and by default. Such measures could consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of data, and enabling the data controller to create and improve security elements. When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of products, services, and applications should be encouraged to take into account the right to data protection when developing and designing these products, services, and applications, and to ensure, with due regard to the state of the art, that data controllers and processors are in a position to fulfill their obligations regarding data protection. The principles of data protection by design and by default must also be taken into account in the context of public contracts.” (the underlining is ours).

Therefore, the measures referred to in Article 25 of the GDPR are not exclusively security measures, as is the case with Article 32 of the GDPR. It is intended that the company or organization integrates within itself, within its organization, and within its ordinary functioning, the protection of personal data.

It should not be an appendix, an additional addition at the end, but an integral and relevant part of it even before the actual processing of personal data begins.

In this way, it is advocated that the protection of personal data be considered from the very beginning, from the decision-making or planning stage.

As can be observed, an obligation is established that permeates the entire organization and implies a continuous process of review and feedback, in order to verify whether the existing technical and organizational measures, of all kinds, implemented by the organization are adequate to meet the requirements of the GDPR and protect the rights of data subjects. Thus, if they are found to be inadequate, they could be modified or, if necessary, strengthened by incorporating new measures that ensure a more adequate protection of personal data.

As previously indicated, Article 5.1(f) of the GDPR is violated when there is a loss of confidentiality or integrity of personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/121

It should be noted that the perspective or angle through which reality is viewed is different from that provided in Article 25 of the GDPR.

In this regard, the GDPR articulates a complete system aimed at ensuring the protection of personal data of citizens. To this end, it focuses on different aspects that must be examined by the data controllers and, as provided by the provision, by the data processors.

Each article constitutes an angle from which to observe reality in order to articulate a set of measures that ensure adequate protection of personal data.

These are complementary angles. All of them must be taken into account and respected, as they are necessary to articulate protection in accordance with the provisions of the GDPR.

In its submissions regarding the initiation agreement, CaixaBank states:

“(…) if the reasoning of the Initiation Agreement is followed, any breach of data protection regulations by a controller would necessarily entail a breach of the principle of data protection by design, since that breach would stem from inadequate compliance with this principle.

Thus, a breach, for example, of the principle of transparency would imply, in the opinion of the AEPD, a non-compliance with Article 25.1, given that the measure consisting of informing the data subjects has not been adequately adopted by design. The same would happen with any of the principles cited in Article 5 of the GDPR (Article 25.1 would be breached by choosing an inadequate legal basis for processing, by failing to avoid processing more data than is adequate, relevant, and necessary for the processing by design, by not adopting measures aimed at ensuring their accuracy by design, by not having adopted rules for retaining them for longer than strictly necessary by design, by not conducting a data protection impact assessment that the AEPD considers necessary, etc.).”

The reasoning presented by CaixaBank is not shared, as if the situation were as described by this banking entity, the vast majority of sanctioning resolutions of the AEPD would consider Article 25.1 of the GDPR to be violated, and this is not the case.

When the AEPD becomes aware of a complaint and decides to open a sanctioning file, it assesses, in light of the circumstances present in the specific case, what infringement or possible infringements of the GDPR may have been committed.

Upon examining the content of the complaint that led to this procedure, it was considered that what was reflected therein aligned with a possible violation of three articles of the GDPR: Article 5.1(f), Article 32, and Article 25, which has subsequently been confirmed.

In response to these three paragraphs, CaixaBank argues in its submissions regarding the proposed resolution:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

"And the fact that the facts are judged from a supposed plurality of perspectives in no way affects the fact that, ultimately, the AEPD considers that the alleged insufficiency of the specific security measure is what determines the violation of the principle of privacy by design, which again leads to the conclusion, already mentioned in the allegations to the Initiation Agreement, that if one follows the reasoning of the AEPD, any violation of the GDPR would simultaneously imply such violation and an insufficient compliance with the principle of privacy by design.

The AEPD seeks to contradict what has just been indicated in the following manner:

'The reasoning presented by CaixaBank is not shared, since if the situation were as this banking entity describes, the vast majority of the sanctioning resolutions of the AEPD would consider Article 25.1 of the GDPR to be violated, and this is not the case. When the AEPD becomes aware of a complaint and decides to open a sanctioning file, it assesses, in light of the circumstances present in the specific case, what infringement or possible infringements of the GDPR may have been committed.

Upon examining the content of the complaint that has led to this procedure, it has been considered that what is reflected therein corresponds to a possible violation of three articles of the GDPR: Article 5.1(f), Article 32, and Article 25. For the reasons stated, the principle of non bis in idem is not understood to be violated.'

In short, the AEPD indicates that what my represented party has pointed out is not applicable because in the present case it has been deemed appropriate to consider the three aforementioned provisions to be infringed while in other cases it does not consider them as such. In our opinion, the reasoning is nonsensical, as it seems to simply reason that the regulated party must comply with what the AEPD deems appropriate at each specific moment, thus leading to a conclusion that is used to rebut the argument maintained by CAIXABANK that its conduct in this case has been inadequate. That is to say, in response to that argument, the AEPD merely states, without reasoning, that there is no basis to invoke that the conduct is inadequate because the AEPD does not share that view.'

Any violation of the GDPR would simultaneously imply such violation and an insufficient compliance with the principle of privacy by design.

The resolutions of the AEPD clearly show that this Agency does not consider that any violation of the GDPR implies, simultaneously, the violation of Article 25 of the GDPR, as CaixaBank seeks to suggest.

On the other hand, the assessment of each complaint, in order to decide whether or not to initiate a sanctioning file, is carried out based on the facts of the specific case being examined.

For the reasons stated in this legal basis, the principle of non bis in idem is not understood to be violated.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es"

IV Response to the allegation regarding the supposed existence of a medial concurrence among the three infractions attributed to CaixaBank:

Below are several paragraphs from the allegations made by CaixaBank regarding the initiation agreement, in which the supposed existence of a medial concurrence among the three infractions attributed to said entity is argued:

"On the other hand, in the denied case that this AEPD does not appreciate the concurrence of the requirements necessary for the application of the principle non bis in idem in the present procedure, there would be no doubt that the Initiation Agreement identifies (and intends to sanction) a plurality of infractions that, allegedly, my client would have committed (which is again flatly denied) when, in reality, each of them would be subsumed and embedded in the others, giving rise to a medial concurrence in the terms provided in Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter, "LRJSP"), according to which:

"When the commission of one infraction necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infraction committed shall be imposed."

Given this, my client cannot be sanctioned for all the infractions in any case, since the commission of the alleged infraction of Article 25.1 of the GDPR would necessarily imply the commission of the infraction of Article 32.1 of that regulation, with the latter non-compliance giving rise to the supposed violation of Article 5.1 f) of the GDPR.

And it is that the AEPD considers (...), that my client has not complied with the obligation imposed in Article 25.1 of the GDPR and at the same time considers that my client has violated Article 32.1 of the GDPR, since it has not applied “appropriate technical and organizational measures to ensure a level of security appropriate to the risk,” which in turn determines a violation of the principle of security, enshrined in Article 5.1 f) of the GDPR.

That is to say, and without prejudice to the fact that, as previously indicated, my client understands that a triple sanction is being imposed for the same facts, what cannot be doubted is that the failure to apply the measures referred to in Article 32.1, and therefore the supposed violation of Article 5.1 f) would necessarily and inseparably arise from the supposed lack of conception or design of the same at the time of determining the means and purposes of the processing. In this way, the AEPD would consider sanctionable the lack of design of a specific security measure, its lack of application, and the very principle that the adoption of that measure aims to protect, which obviously could only arise from that lack of prior design, thus meeting the requirements necessary for the appreciation of medial concurrence in the present case.

Therefore, either the same facts are being sanctioned three times, or two of the infractions can only necessarily be a consequence of the first.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/121

According to established jurisprudence (among others, Judgment 339/2015 of September 25, 2015, of the National Court - appeal 262/2014 - which cites the Judgment of the Supreme Court of February 8, 1999, - appeal 9/1996 -) “the application of medial concurrence requires a necessary derivation of some infractions concerning others and vice versa, so it is essential that one cannot be committed without executing the other.” Thus, there must be “such a relationship between the concerned infractions that one necessarily derives from the other, so that it is not possible to commit one without executing the other” (among others, Judgment of the National Court of December 26, 2013, - appeal 416/2012).

Well, as indicated, it is evident that such a relationship exists between the three infractions that are intended to be imputed against my client, as previously indicated.

First of all, Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR.

1. The GDPR is a complete system.

The GDPR is a directly applicable European regulation in the Member States, which contains a new, complete, and global system aimed at ensuring the protection of personal data uniformly throughout the European Union.

In relation, specifically and also, to the sanctioning regime provided therein, its provisions apply immediately, directly, and integrally, foreseeing a complete and gapless system that must be understood, interpreted, and integrated absolutely, completely, and integrally, thus leaving its ultimate purpose intact, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data. The contrary results in a diminishment of the guarantees of the rights and freedoms of citizens.

In fact, a specific example of the non-existence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infraction (art. 83.2 of the GDPR) or specifies the existing rule concerning a possible medial concurrence (art. 83.3 of the GDPR).

To the above, we must add that the GDPR does not allow the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of art. 83.7 of the GDPR).

The LOPDGDD only develops or specifies some aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the purpose intended by the European legislator is to implement a uniform system throughout the European Union that guarantees the rights and freedoms of individuals, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this regard, Recital 2 of the GDPR states that,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

54/121

“(2) The principles and rules regarding the protection of natural persons in relation to the processing of their personal data must, regardless of their nationality or residence, respect their freedoms and fundamental rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of natural persons.” (emphasis added)

It further states in Recital 13 of the GDPR that,

“(13) To ensure a consistent level of protection for natural persons throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary that provides legal certainty and transparency to economic operators, including microenterprises and small and medium-sized enterprises, and offers natural persons from all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to ensure consistent supervision of personal data processing and equivalent penalties across all Member States, as well as effective cooperation between the supervisory authorities of the different Member States. The proper functioning of the internal market requires that the free movement of personal data in the Union is not restricted or prohibited for reasons related to the protection of natural persons in relation to the processing of personal data.” (emphasis added)

In this system, what is decisive in the GDPR is not the fines. The corrective powers of the supervisory authorities provided for in Article 58.2 of the GDPR combined with the provisions of Article 83 of the GDPR show the prevalence of corrective measures over fines.

Thus, Article 83.2 of the GDPR states that “Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures referred to in Article 58(2)(a) to (h) and (j).”

In this way, the corrective measures provided for in Article 58(2)(a) to (h) and (j) of the GDPR take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed alongside the corrective measures or in substitution for them.

And all this with the aim of enforcing compliance with the GDPR, preventing non-compliance, promoting compliance, and ensuring that the infringement is not more profitable than compliance.

Therefore, Article 83.1 of the GDPR provides that “Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

Fines must be effective, proportionate, and dissuasive to achieve the purpose intended by the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/121

In order for this system to function with all its guarantees, it is necessary for several elements to be deployed in an integral and complete manner. The application of rules foreign to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to

aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the case of Spain - or due to the application of a different mitigating circumstance than that provided for in the GDPR, would undermine the effectiveness of the system, which would lose its meaning and teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and deterrent. In this way, the interested parties would also be deprived of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR has its own principle of proportionality that must be applied in its strict terms.

2. There is no legal gap, there is no supplementary application of Article 29 of the GDPR.

In addition to the above, it should be noted that there is no legal gap regarding the application of the mitigating circumstances provided for in Article 29 of the LRJSP. Neither the GDPR allows nor does the LOPDGDD provide for the supplementary application of the provisions of Article 29 of the LRJSP. In Title VIII of the LOPDGDD relating to "Procedures in the event of a possible violation of data protection regulations," Article 63 that opens the Title states that "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, there is absolutely no establishment of a subsidiary application regarding the LRJSP, which does not contain any provision related to any administrative procedure in its wording.

Just as the AEPD is not applying the aggravating and mitigating factors provided for in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap nor supplementary application of the same, nor can the section relating to mitigating circumstances be applied for the same reasons.

The written allegations to the proposed resolution formulate allegations concerning what has just been indicated and insist on the existence of a clear case of mitigating circumstances.

In response to these second allegations made by CaixaBank regarding the application of mitigating circumstances in the terms of Article 29 of the LRJSP, the AEPD has not indicated at any time:

- That the application of the GDPR and the LOPDGDD excludes the application of the rest of the legal system.
- That the application of the GDPR and the LOPDGDD excludes the consideration of existing jurisprudence in the sanctioning procedures processed by the AEPD.
- That the application of the GDPR and the LOPDGDD excludes the application of the principles in the sanctioning procedures processed by the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/121

Sanctioning Procedure.

- That the application of the GDPR and the LOPDGDD excludes the application in the sanctioning procedures processed by the AEPD of the principle of proportionality.
- That there cannot exist at any time, always considering the circumstances of the specific case, a medial concurrence (although this is not the case in the procedure now examined).
- That the LRJSP is not applicable to the AEPD.

The AEPD, strictly complying with all applicable regulations, which includes, as could not be otherwise, the Spanish Constitution and the Charter of Fundamental Rights of the European Union, and the principles of the sanctioning procedure, asserts that:

- The principle of proportionality is applicable to the sanctioning procedure.
- The European legislator has regulated the principle of proportionality in Article 83 of the GDPR.
- Given that the GDPR has a complete and specific regulation of the principle of proportionality,

resulting in the absence of any legal gap, Article 29 of the LRJSP is not specifically and concretely applicable.

Regarding the alleged confusion between supplementary and subsidiary application, we will begin by literally repeating what was indicated in the resolution proposal:

“2. There is no legal gap, there is no supplementary application of Article 29 of the GDPR.

In addition to what has been stated, it should be noted that there is no legal gap regarding the application of the medial concurrence provided for in Article 29 of the LRJSP. Neither the GDPR allows nor the LOPDGDD provides for the supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to “Procedures in case of possible violation of data protection regulations,” Article 63, which opens the Title, states that “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures.” While there is a clear reference to the LPACAP, there is absolutely no subsidiary application regarding the LRJSP, which does not contain any provisions related to any administrative procedure.

Just as the AEPD is not applying the aggravating and mitigating factors provided for in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap nor subsidiary application of the same, nor can the section relating to medial concurrence be applied for the same reasons.”

As we indicated earlier, the application of rules external to the GDPR regarding the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

57/121

Determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the case of Spain - or due to the application of a different legal competition than that provided for in the GDPR, would undermine the effectiveness of the system, which would lose its meaning and teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and deterrent. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

It should be clarified, beforehand, that subsidiarity refers to cases in which a specific situation is not regulated by a certain norm, creating a legal gap, leading to the application of another legal norm that regulates such a situation, provided that it does not conflict with the legal system.

Whereas subsidiarity refers to a competition of norms, which means that for a certain case, two or more norms may be applicable, such that the subsidiary norm yields in favor of the principal one.

Well, given the literal interpretation of what was indicated by the AEPD, both subsidiarity and subsidiary were examined to conclude the non-application of Article 29 of the LRJSP but rather Article 83 of the GDPR in relation to the principle of proportionality.

It was indicated:

- That the principle of proportionality applies to the sanctioning procedure.
- That the principle of proportionality is fully regulated in Article 83 of the GDPR.
- That there is no legal gap.
- That neither the GDPR nor the LOPDGDD refer to the application, due to the existence of a legal gap, of Article 29 of the LRJSP.
- That, in the procedures processed by the AEPD, we emphasize, for the administrative procedures processed, the subsidiary application of the general norms on administrative procedures is provided for.

- That in the procedures processed by the AEPD, we emphasize, for the administrative procedures processed and not in relation to the principles of the sanctioning procedure, there is no subsidiary application of the LRJSP established in the LOPDGDD.
- It was concluded that there was neither subsidiarity nor subsidiarity that would lead to the application of Article 29 of the LRJSP.

In relation to the citation of the Guidelines 04/2022 of the EDPB on the calculation of administrative fines in accordance with the GDPR, in its version 2.1, adopted on May 24, 2023, in its section 22 reference is made to three types of concurrency, namely, of infringement, unity of action, and plurality of actions: "When examining the analysis of the traditions of the Member States regarding concurrency norms, as indicated in the jurisprudence of the CJEU, and taking into account the different areas of application and legal consequences, these principles can be grouped approximately into the following three categories: - Concurrency of infringements

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
58/121

(chapter 3.1.1), - Unit of action (chapter 3.1.2), - Plurality of actions (chapter 3.2).

In cases of concurrent violations, the provision established in Article 83.3 of the GDPR applies, which sets a quantitative limit in these cases of concurrency: "If a controller or a processor intentionally or negligently violates various provisions of this Regulation for the same processing operations or related operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements." (the underlining is ours).

If we were to accept the argument put forth by CaixaBank, it could be inferred that the "full applicability of medial concurrence" referred to the preferential application of Article 29 of the LRJSP, in its sole intention to pay a single fine instead of the three imposed, displaces or nullifies the validity of Article 83.3 GDPR, which is entirely contrary to the legal order.

Furthermore, at this moment, we must remember that the severity of the infringements of the GDPR is determined according to the rules established in it and not in the LOPDGDD. The classification of infringements is regulated in Article 83, paragraphs 4, 5, and 6 of the GDPR, while the qualification of infringements as very serious, serious, or minor solely for the purposes of prescription is provided in Articles 72, 73, and 74 of the LOPDGDD. However, contrary to what the claiming party indicates, the severity of the infringements is not regulated in these provisions of the LOPDGDD.

Finally, and no less important, the AEPD does not sanction for the same offense, as claimed by the responding party, but it has been established through proven facts not contested by CaixaBank, the commission of three differentiated infringements, classified in a differentiated manner, and there is, moreover, in the specific case, no medial concurrence.

For all the above, this allegation is dismissed.

On the other hand, this Agency, in light of what happened in the specific case examined, states that medial concurrence cannot be appreciated in it.

As previously indicated, Article 5.1.f) of the GDPR is violated when there is a loss of confidentiality or integrity of personal data, which may or may not occur as a result of deficiencies in security measures. In this case, there has been a violation of Article 5.1.f) of the GDPR, but it does not necessarily stem from deficiencies in security measures. The reality analyzed is much more complex.

As an example, the lack of availability of the proof of the update of contact data carried out by the claimant on February 1, 2021:

At first, there was a (...).

At that moment, (...) For this reason, (...) and the banking entity did not detect that a breach of personal data had occurred.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

59/121

However, once the breach was detected by CaixaBank (...), the loss of availability extended over time, and it cannot be asserted that it was solely determined by technical reasons. The claimant (...).

As highlighted in the legal basis II (Claim process), for the availability of the proof of data update to finally occur, the receipt by the banking entity of the letter from this Agency dated June 7, 2023, regarding the opening of a trial period I, in which (...), was decisive.

In conclusion, it cannot be stated that the alleged violation of Article 5.1 f) necessarily and inseparably causes the supposed lack of conception or design of the same at the time of determining the means and purposes of the processing.

Regarding Articles 25 and 32 of the GDPR, as will be analyzed later, it should be considered that both articles would have been violated, although it cannot be asserted that the violation of Article 25 necessarily derives from that of Article 32 or vice versa.

As will be indicated later, it is considered that certain issues that could be considered violations of Article 25 of the GDPR would be sanctionable even if a breach of personal data had not occurred. For example, the design of the procedure that articulates the processing of documents submitted by interested parties to CaixaBank that affect the protection of personal data. Another example, the design adopted after (...) CaixaBank was unaware of the existence of the breach of personal data.

In conclusion, the reasons for dismissing the allegations made by CaixaBank regarding medial concurrence have been thoroughly presented.

Furthermore, its application to a complex case, with so many nuances, such as the one being examined in this sanctioning procedure, would also not be appropriate.

V Analysis of the violation of Article 5.1 f) of the GDPR

CaixaBank, in its allegations, considers that there has been no violation of Article 5.1 f) of the GDPR; this assertion is not shared.

Next, the case subject to this sanctioning procedure will be analyzed from a specific angle or perspective: that provided in Article 5.1 f) of the GDPR.

The referred article provides:

“1. Personal data shall be:

f) processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures (‘integrity and confidentiality’).”

The content of this article has been violated:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

60/121

On one hand, a personal data breach has occurred, resulting in the loss of confidentiality of personal data relating to two individuals:

1. The sender of the transfer: another client of CaixaBank.

2. The beneficiary of the transfer: a third party, client of another banking entity.

In the sixth proven fact, the personal data that appeared on the transfer receipt and have been disclosed are listed.

On the other hand, the claimant did not have access to the receipt of the contact data update that had been carried out on February 1, 2021, until (...) (availability breach), resulting in the unavailability of the claimant's personal data that appears in it, as reflected in the following table:

DATE

What happens on that date

Claimant's situation

01/02/21

Contact data update. (...).

The claimant did not have available (...) the receipt of the contact data update carried out on February 1, 2021.
20/02/21
(...).

The claimant continues to not have available (...) the receipt of the contact data update carried out on February 1, 2021.
The claimant continues to not have available (...) the receipt of the contact data update carried out on February 1, 2021.
21/06/21
CaixaBank carried out a (...).

31/10/21
The claimant (...).

02/11/21
The claimant received (...)

10/11/21
CaixaBank sent (...)

09/02/22
CaixaBank carried out (...)

10/02/22
The claimant (...) filed a complaint, very similar to the one already raised before CaixaBank (...), to the Conduct Department of Entities of the Bank of Spain.

05/05/22
The Conduct Department of Entities forwarded the complaint to the AEPD, with entry in the General Registry of the Agency on 10/05/22.

08/06/22
CaixaBank received the transfer and the request for information from the AEPD. (...).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

61/121
22/07/22
CaixaBank verified that (...).

CaixaBank sent a letter to the claimant highlighting this circumstance and a letter, with very similar content, to the AEPD in response to the transfer and the request for information.

04/08/22
CaixaBank prepared (...).

10/08/22
Admission of the complaint for processing.

12/08/22
The claimant sent an email to the Customer Service of CaixaBank and forwarded a copy of it to the AEPD. In it, he expressed his disagreement with how CaixaBank was handling his complaint. He also requested that the receipt of the contact data update carried out on 01/02/21 (...).

23/09/22
First request for information to CaixaBank by the Inspector.

04/10/22
Letter from CaixaBank in response to the request for information. (...).

05/10/22
CaixaBank (...).

21/11/22
Second request for information made by the Inspector.

12/12/22

CaixaBank (...).

13/12/22

Letter from CaixaBank in response to the second request for infringement. (...).

27/01/23

Agreement to initiate

07/06/23

Test practice I, sent by the AEPD on June 7, 2023, (...).

20/05/23

(...)

CaixaBank claims that on this date the claimant had available (...) the receipt of the contact data update that he had carried out on February 1, 2021.

In the written allegations to the resolution proposal, CaixaBank denies the existence of an availability breach. In this regard, it highlights:

"The Resolution Proposal makes various considerations throughout its legal grounds regarding the existence of a breach in this case."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

62/121

of the availability of the Claimant's personal data, since he could not provide the supporting document for the modification made to my represented party's contact details.

(...)

As can be seen, the Proposal for Resolution at no time indicates that the interested party has not had access to his personal data and that the same has not been available both to him and to my represented party, but rather qualifies the facts as a breach of availability as a consequence of the fact that (...) the supporting document of said update.

And at this point, it is necessary to indicate that a breach of availability in data protection matters must refer to the accessibility of the data and not to the related supporting documents. Thus, the AEPD itself in its Guide for the notification of security breaches, accessible on its website at the link <https://www.aepd.es/documento/guia-brechas-seguridad.pdf>, states that "a breach affects the availability of personal data when they have been temporarily or permanently inaccessible to those who legitimately must be able to process or access them."

In the same vein, the Article 29 Working Party (hereinafter, "WP29") in its "Guidelines on the notification of personal data security breaches in accordance with Regulation 2016/679," adopted on October 3, 2017, and last revised and adopted on February 6, 2018, in terms that are subsequently expressly reiterated by the European Data Protection Board (hereinafter, "EDPB") in its "Guidelines 9/2022 on the notification of personal data security breaches in accordance with the GDPR," states that a breach of availability occurs "when there is an accidental or unauthorized loss of access to personal data, or the destruction of the same," adding that "a security incident that causes the unavailability of personal data for a period of time is also a type of breach, as the absence of access to the data can have a significant impact on the rights and freedoms of individuals."

That is to say, for us to be faced with a breach of availability, it must refer to personal data, so that the same (not the documents or supporting evidence of the processing, but the data itself) cannot be accessible to the interested parties or to the data controller and, ultimately, to those who are entitled to carry out such access.

However, the Proposal for Resolution refers solely and exclusively to the accessibility of the document, never denying that the data has remained accessible to the interested party in (...) nor that he could obtain the certificate of his modification by going to the offices of CaixaBank.

And this confusion between the personal data and the document arises from the very evidence that was requested from my represented party by the AEPD (...)

Therefore, there exists, if we may say so, an inadequate application by the AEPD of the concept of breach of availability: the data has always remained accessible and available to the interested party,

who could permanently, with
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
63/121

... to submit them in their own (...). This fact is not denied at any moment in the Proposal for Resolution, which only refers to the accessibility of the document.

And having established the above, my represented party considers that the AEPD carries out an extensive interpretation of the concept of personal data availability breach, which leads to the application by it of provisions that are not related to personal data protection regulations, which, CAIXABANK considers, constitutes an overreach in the use of its powers.

(...) my represented party understands that the AEPD exceeds its powers, because what regulation obliges CaixaBank to publish online the proof of the transaction?

What would happen if this online document management service were not offered to clients and was simply sent by postal mail, which was the standard practice in the sector until now? Would any rule be violated?

The answer can only be that nothing would happen, because neither banking regulations, applicable to my represented party's activity, nor data protection regulations, nor any other, impose on CAIXABANK (...).

The AEPD has taken a good practice of CAIXABANK, which represents an improvement aimed at facilitating the experience of its clients, and has turned it into a legal obligation subject to sanction.

Does this mean that, (...) ?

(...)

From this, it can be inferred that the AEPD considers it appropriate to impose on my represented party additional documentary obligations beyond those established in banking regulations and that it is also competent to assess the possible harm to the interested party from alleged damages, which have no relation whatsoever to their fundamental right to data protection, given that there is no doubt, and the AEPD acknowledges that the interested party could permanently access the data, even if that access did not occur in the location that the AEPD seems to consider most appropriate.

CAIXABANK considers that in this case this interpretation is excessive: if the data is available, the damages that could potentially be caused to the interested party by not having a supporting document that, on the other hand, CAIXABANK is not obliged to issue, would be resolved in court before the civil jurisdiction.

My represented party respectfully understands that the AEPD cannot consider that any prejudice, of any nature, which could only remotely and extensively relate to the existence of personal data processing (not with the violation of its regulatory framework, but with the existence of some type of processing) could justify its intervention, even when the issue does not relate to personal data protection."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

64/121

In response to this allegation, it is worth noting that, in relation to availability, the "Guide for the Notification of Personal Data Breaches" prepared by the AEPD states the following:

"Availability: A breach affects the availability of personal data when it has been temporarily or permanently inaccessible to those who legitimately should be able to process or access it. This situation may occur due to events affecting the personal data themselves or also due to events affecting the systems used for their processing. For example, it includes cases of encryption of personal data or information systems caused by ransomware-type malware, loss of paper documentation containing personal data, or the inability to access a data storage (physical or logical

access).

For the data controller, it is important to determine whether availability has been restored or is in the process of being restored, since recovering the data and processing systems is the way to mitigate the damage that such personal data breaches can cause. To this end, data controllers must establish recovery strategies and procedures for such situations, including backup procedures, incident recovery, and data governance strategies.

Example: In availability breaches caused by ransomware-type malware where the data controller can confidently rule out data exfiltration and personal data and processing means can be restored without significantly affecting the services provided, it can be considered that the risk has been adequately mitigated. In the event that the recovery of data and/or processing is prolonged over time significantly affecting the services provided, for example, due to the absence or malfunction of data backup systems and processes, it can be concluded that the risk has not only not been mitigated, but is materializing and causing various types of harm to the interested parties.

" (the underlining is ours).

Regarding the specific case under examination, the proof of the data update carried out by the complainant on February 1, 2021, contained personal data.

As CaixaBank highlights in its allegations to the proposal for resolution, such personal data had to be accessible to those who were authorized to carry out such access: the data controller and the complainant.

CaixaBank was providing a service to the complainant, who was its client. From the perspective of personal data protection, the personal data had to be available to the client.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

65/121

In the written allegations regarding the initiation agreement, CaixaBank stated:

"However, said with due respect, the aforementioned availability gap did not occur in practice: the Claimant had their contact details modified from the very moment they made the request for modification, as could be verified at any time by cross-checking their personal data (...). Likewise, the accreditation of the request made was at all times available to the interested party, who could have requested it from CAIXABANK even though, it is true, they could not access it (...), during the period mentioned in the Agreement."

CaixaBank claims that the client could have verified at any time that the update of contact details carried out on February 1, 2021, had been completed. Not through the receipt, which was not available to the claimant until (...) (proven fact tenth), but by making other inquiries in (...) or requesting it from the banking entity.

Next, we will accompany the claimant in these verifications.

Once the update of contact details was completed, the claimant accesses the section of their (...).

We know for certain what the claimant was viewing in this section, as they provided an image along with their complaint to CaixaBank dated October 31, 2021 (DOCUMENT NUMBER 3, which accompanied CaixaBank's letter dated July 18, 2023, prepared in response to the practice of evidence II).

In the proven fact eleventh, the description of said image has been included:

- (...).

(...)

(...)

Through this means, the claimant could not access the receipt of the update of contact details that had been made (...), since (...) the receipt of the transfer made on February 1 by Mr. C.C.C..

The only information they could access was the following:

- That it was an update of contact details.

- That it had been carried out on February 1.

- That the (...).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

66/121

The problem is that the data they could visualize did not correspond to the content of the receipt they accessed (transfer made by Mr. C.C.C.).

As highlighted in proven fact twenty-first, on August 12, 2022, the claimant still did not have the receipt of the update of contact details carried out on February 1, 2021, and in a letter addressed to CaixaBank's customer service on that same date, they indicated:

“But there is still an error that compromises the protection of Caixa customers' data, and if I have received this document, who has received the document of (...) of my contract with my banking and personal data?

The possibility of having access to a receipt with the personal data of two other people, whom they did not know, caused the claimant a loss of trust regarding the processing of their banking data by CaixaBank.

At this point, in CaixaBank's opinion, the claimant should have sought other means in their (...) to verify the update of their contact details carried out on February 1, 2021.

Through this means, the banking entity claims that they could have verified that the (...).

However, the information available through this complex combined means (consultation of (...) and the section of their (...) where the (...) was listed) did not allow them to access all the data that appeared on the receipt.

CaixaBank, for its part, as the data controller, did have access to all the information. The referred information is included in document 2, which accompanied its letter of December 13, 2022, prepared in response to the second information request from the Inspector.

The mentioned document contains numerous personal data. We will highlight three of them: (...).

The claimant did not have those three pieces of personal data available.

The examination carried out by the AEPD is based on a risk-based approach concerning the rights and freedoms of the interested parties, focusing on the natural person whose data is being processed.

In this regard, it is worth recalling that Recital 75 of the GDPR, which takes a broad approach to the risks to the rights and freedoms of natural persons, provides:

(75) The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, in part.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

67/121

particularly in cases where the processing may lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where the interested parties are deprived of their rights and freedoms or are prevented from exercising control over their personal data; (...)” (the emphasis is ours)

Based on the described approach, it is emphasized that the claimant did not have access to all of their personal data.

On one hand, by not having the proof of the update of contact data, they found themselves in a worse situation than any other customer of the same banking entity who had carried out the same operation (updating contact data) and had been able to access (...) the proof of that operation and all their personal data contained therein.

The proof of a financial transaction is of great importance. It acts as a mirror, reflecting the content of the banking operation that has been carried out.

- On one hand, it allows the customer of the banking entity to verify, immediately after carrying out the

operation, that it has been executed correctly, allowing them to react otherwise.

- On the other hand, it allows the customer of the banking entity to prove to the banking entity itself or to third parties their signature, the day, the date, and the exact time when they carried out the banking operation, as well as its content.

Furthermore, the lack of such proof prevented them from having access to some of their personal data, causing a loss of control and availability over personal data that concerned them. For example, they could not verify its accuracy, confirm that their signature was indeed their signature and that it was correctly reflected in the document.

They also could not prove to third parties (...) that they had updated their personal data on February 1. Such proof could be relevant, as it was modifying the (...).

(...).

(...).

As can be seen, the rights and freedoms of the claimant could be affected.

The argument presented by CaixaBank in its written submissions to the proposed resolution is not shared, as it would imply that the banking entity would have no incentive to ensure the resilience of the system or a rapid restoration. This circumstance clearly contradicts the provisions of the GDPR and what is indicated in the “Guide for the Notification of Personal Data Breaches” prepared by the AEPD. In which it states:

“(...) Article 32.1 specifically enumerates a non-exhaustive set of security measures that could be considered to manage risk through security measures in processing, such as:

- Measures aimed at ensuring confidentiality, integrity, and availability
- Measures to ensure the resilience of processing systems and services, and to provide the capacity to restore the availability and access to personal data quickly in the event of a physical or technical incident.” (the emphasis is ours).

For the reasons stated, the allegation made by CaixaBank is rejected.

As will be indicated later, the update of contact data carried out by the claimant is a kind of right of rectification, which is directly performed by the customer. It is necessary for the banking entity to provide them, as soon as they have signed, with proof of the banking operation carried out in the designated place for this purpose (in this case, at the (...).

In relation to this issue, CaixaBank has made various allegations regarding the consideration that the update of contact data carried out by the claimant should be regarded as a kind of right of rectification, summarized on page 20 of its written submissions to the proposed resolution:

“Even in the event that the request for modification is considered ‘a kind of right of rectification’ to which a response should have been given, CAIXABANK had made available to the applicant a system of remote, direct, and secure access to personal data that permanently guaranteed access to all of it, having adequately informed the interested party about this (...), so it cannot be considered that access to it constitutes an inappropriate burden for the interested party. Furthermore, once (...), CAIXABANK provided the interested parties with the corresponding document in a (...), significantly less than the month referred to in Article 12.3 of the GDPR.”

Firstly, as has just been stated, (...) the claimant did not have access to all of their personal data.

Secondly, it can be asserted that the update of contact data, (...) bears clear similarities to the right of rectification. It is merely a means provided by the entity for its customers to rectify their personal data.

For this reason, the proposed resolution referred to “a kind of right of rectification.”

If the banking entity has decided to design a system based on which (...), this Agency cannot understand the reason why the proof of a banking operation...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

69/121

The receipt of such characteristics must occur one month later (let us remember that the one-month period regarding the exercise of rights under the GDPR by an interested party is a maximum provision; organizations must respond to the interested party as soon as possible).

On the other hand, the paragraphs reproduced by CaixaBank in its written allegations to the proposal for resolution have been taken out of context.

In these paragraphs, related to legal basis VII, it was argued that the design (...) had been developed from an approach centered on the interests of the banking entity and not the client. It was considered that, by making such a design, CaixaBank was transferring to the client a problem derived from its internal operations, considering it normal that the client did not have the proof of the banking update that had just been carried out until (...) after having completed it.

In conclusion, despite the allegations made by CaixaBank, it can be understood that the content of Article 5.1 f) of the GDPR has been violated.

VI

Analysis of the Violation of Article 32 of the GDPR

On this occasion, the case subject to this sanctioning procedure will be analyzed from another angle or perspective: whether the technical and organizational security measures adopted were adequate.

CaixaBank, in its written allegations to the initiation agreement, considers that there has also been no violation of Article 32 of the GDPR. Once again, the assessment made by the banking entity is not shared.

Article 32 regulates the security measures applied.

The specific case subject to this sanctioning procedure will now be examined.

1. (...):

From the information provided by CaixaBank in its writings of December 13, 2022, February 20, and July 18, 2023, it is evident that (...) was key, both to prevent the occurrence of the personal data breach and (...), which allowed for the detection that something anomalous had just happened.

In the CaixaBank document of December 13, 2022, it is indicated, as recorded in the proven facts twenty-seventh and forty-sixth:

“(…).

(…)

(…).

(…)

(…)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

70/121

(…)

On the other hand, in the document (...), DOCUMENT NUMBER 7 provided by CaixaBank along with its written allegations, reflected in the proven fact twenty-ninth, it is indicated:

“MEASURES ADOPTED TO IMPROVE ROBUSTNESS AND ELIMINATION OF RISKS

(…)

Likewise, the content of the document prepared by CaixaBank on July 18, 2023, regarding this issue is included in the proven fact thirty-fifth. Below, only the part of its content related to the period in which the security breach occurred is reflected:

“- (...):

(...):

1. (...).

2. (...).

(...).”

The last paragraph highlights that the two banking transactions or operations were carried out. In the analyzed case:

- The update of the contact details of the claimant (first document).

- The transfer made by Mr. C.C.C. (second document).

Therefore, (...).

(...)

(...)

(...).

Subsequently, on ***DATE.1 (...). However, the personal data breach subject to examination in this file, and this is important, continued to go unnoticed (...).

(...).

In the written allegations to the proposal for resolution, CaixaBank emphasizes:

"The AEPD attempts to downplay the effect of the measure adopted, considering that it was carried out with an intention different from that which generated the result: to eliminate the possibility of the breach occurring. To this effect, it refers to the proven fact seventh, which we understand should be considered the thirty-second, given that the seventh is not related to the (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

71/121

"CaixaBank decided (...)."

Although what is stated in this proven fact may be considered true, it must nevertheless be indicated that the interpretation of the aforementioned fact made by the AEPD is incomplete, such that the conclusions reached as a consequence of it may be considered, with due respect, biased.

It is one thing that my client was not aware of the specific fact that motivated the complaint that gave rise to the present proceedings, and another entirely different matter that it cannot be considered that the "(...) did not have as an objective, among others, the increase of the security of said systems."

That is to say, the AEPD uses the reproduced text to try to assert, although without any supporting element, that the review carried out by my client had as its sole and exclusive (...), considering that such improvement could in no way take into account the enhancement of the security of the same or the adoption of measures that could aim not only to minimize but to exclude the (remote) risk that CAIXABANK's clients could suffer in their assets and rights. The AEPD simply guesses what CaixaBank's motivation was.

But even in the denied assumption that my client had not taken into account such (remote) risks, which CAIXABANK flatly denies, the motivation that would have led to the adoption of the mentioned measure would be irrelevant, as long as it eliminated the aforementioned risks.

My client considers that the AEPD cannot deny the relevance of a measure to guarantee the fundamental right to data protection merely because it has not adopted the procedure that the AEPD deems appropriate, given that what is important is the reduction (in this case, elimination) of the risks that the processing may produce on the affected parties.

The AEPD minimizes the effect of the indicated measure by referring to (...). However, in addition to the fact that it is necessary to indicate that the measure (...) of the Claimant occurred at the very moment it was requested, it is not relevant, from the perspective of data protection regulations, that the (...) of the same (...), as analyzed in the first of the allegations contained in this document.

In response to this allegation, it is highlighted that in CaixaBank's letter dated December 13, 2022, prepared in response to the second request for information from the Inspector, the claiming party stated:

"As for the actions carried out as a consequence of this specific event, as indicated, as a solution and measure of robustness, we (...)."

This response implied to the AEPD that (...) had been an action adopted by the banking entity in order to resolve the personal data breach that occurred on February 1, 2021.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

72/121

The problem is that, as highlighted by the proven fact thirty-second (...), it was materially impossible for

such action taken by the banking entity to have been adopted as a solution to the personal data breach.

The document from CaixaBank dated June 28, 2023, prepared in response to the evidence practice I, clarified that (...).

That is to say, this (...) was not a specific action taken by CaixaBank in order to resolve the personal data breach, of which it was still unaware.

We do not know the motivation that led to the execution of this (...).

What this fact does reveal is that when the (...), at first, deleted the proof of the transfer made by Mr. C.C.C. (...). Subsequently, as the AEPD acted (new request for information from the Inspector, initiation agreement of the sanctioning file, and three evidence practices), it adopted some additional measures.

In the written allegations to the proposed resolution, CaixaBank highlights:

“The second of the considerations relates to the factual account made in the legal basis II of the Proposal for Resolution, and in particular to the consequences derived from the modification produced in the systems of my represented party on date ***DATE.1.

Indeed, the Proposal enumerates a factual sequence of events that it considers relevant in the present procedure, deducing from them a series of conclusions related to the alleged delay of my represented party in becoming aware of the existence of the security breach that occurred in this case.

However, CAIXABANK considers that these conclusions are, with due respect, inaccurate, as they only take into account aspects that may be conducive to assessing the responsibility of my client, without considering others that are particularly relevant in the present procedure, the most important of which is the one previously pointed out, which occurred on ***DATE.1 and consists of the (...).

And, CAIXABANK understands that if objective conclusions are to be drawn from the factual sequence produced in this case, this fact is crucial, since, as has been demonstrated throughout the procedure and the Proposal for Resolution itself acknowledges, (...) (and since the aforementioned date), it is materially impossible for a client of my represented party (...). That is to say, from ***DATE.1, the generation of a security breach as described in this procedure is materially impossible, and therefore, the breach of confidentiality of the documents generated as a result of the transactions ordered by CAIXABANK's clients will also not be possible.

Moreover, aside from the stated factual assumption, the Proposal for Resolution, while acknowledging it, seems to pay little attention and grant little relevance to a fact of such significance that has led to any similar claim to that made in this case (let us remember that this is a unique claim) becoming materially impossible from a date nearly two years prior to the adoption of the Agreement to Initiate the present procedure.

And this fact is an undisputed fact that, without prejudice to any evaluations that the AEPD may make, should be recorded as a conclusion of the factual account incorporated into the legal basis II of its Proposal for Resolution.”

First of all, the proposed resolution does not recognize that (...) materially prevented the events that led to the breach from recurring in the future.

It would be to assert that the existing risk after the (...) was equal to zero, and this Agency does not consider it so, as will be explained in this resolution.

Secondly, CaixaBank states that the (...) is a crucial fact, since, in the opinion of this financial entity, the personal data breach was materially impossible (...).

Regarding this allegation, it can be stated that:

1. If the (...) was of crucial importance, it is extremely negligent that (...).
2. Likewise, it is striking that when (...), and not as a consequence of a (...), there are no elements indicating that it responded to a proactive data protection action.
3. It is also noteworthy that, despite being involved in the security breach, an essential and crucial element such as (...), the banking entity did not determine the cause of the personal data breach until (...).
4. CaixaBank states that, after (...), the personal data breach is materially impossible.

As will be explained in legal basis VII, the current design of the system relies on (...). If such (...) could lead to a recurrence of the personal data breach.

CaixaBank has considered that (...), is the solution. However, as will be analyzed later, (...), in such a way that the problem has not been solved at its root and, as a consequence, the risk remains latent.

2. (...):

This unique identifier will be analyzed in its capacity as a security measure.

The personal data breach shows that (...) since in the document from CaixaBank dated December 13, 2022, it is highlighted, as recorded in the proven fact twenty-seventh:

“(…)”

Regarding (...), the document from CaixaBank dated December 13, 2022 indicates:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

74/121

“(…)”

(…)”

(…)”

(…)”

(…)”

(…)”

As can be seen, (...) and this caused the claimant to access the content of a receipt or proof of a transfer made by another client of that banking entity.

In the written allegations to the proposed resolution, CaixaBank states:

“In relation to the alleged violation of Article 32 of the GDPR, the AEPD considers in its legal basis VI that (...)”

And in this regard, it is necessary to refer to what was indicated in the first of our allegations: (...)”

In response, it is noteworthy that:

As will be explained in legal basis VII (...).

On the other hand, what is stated in this legal basis allows us to appreciate significant shortcomings from the perspective of security measures at the time when the breach of personal data subject to this file occurred.

Considering all these circumstances, it is not possible to assert, in any way, that the risks have been reduced to zero.

In the written allegations to the initiation agreement of February 20, 2023, CaixaBank invokes the Judgment of the Supreme Court of February 15, 2022.

Subsequently, in the written allegations to the proposed resolution, in the allegation regarding an alleged violation of the principle of non bis in idem, CaixaBank again cites in its defense the Judgment of the Supreme Court No. 188/2022 dated February 15, 2022, arguing that it determines that security measures are of means and not of results, a matter not disputed by the AEPD.

First of all, we must point out that this judgment is issued under the regulations prior to the GDPR, in which, according to the system provided in the LOPD and in the RLOPD, security measures were perfectly standardized. We have moved from a system with standard and static security measures for any data controller to specific security measures for each organization (adapted to its characteristics and idiosyncrasy), which consider the specific risks of the entity in question; moreover, they are now dynamic, in such a way that they are not exhausted with the implementation of the security measures appropriate to the risk at the beginning of the processing, but must be adapted to the risks that may arise.

The new regulation provided in the GDPR significantly expands the obligations of the data controller and its scope of action and responsibility, now clearly extending to the actions carried out by its data processors, which fall within its area of responsibility.

In the judgment, there is no deliberation on the adequacy of the security measures of the then data controller, that is (...), since they were not examined by the AEPD; a data processor was reported, who did not have the appropriate security measures implemented, an obligation that clearly stemmed from Article 79 and following of the RLOPD, which indicated what, specifically, the security measures were

that, according to Title VIII of the aforementioned Regulation, data processors should implement. Notwithstanding the above, the judgment also indicates that the system was not used properly, which would have prevented the leak.

And all this without either the sanctioning resolution or the judgment indicating or deducing that (...) had, therefore, adequate or inadequate security measures according to the then Title VIII of the RLOPD, nor that the fact that they were not adequate exempted it from its responsibility, which fell on the data processor.

Secondly, the cited Judgment of the Supreme Court considers, in relation to an infringement of Article 9 of the LOPDP, that "the obligation that falls on the data controller and on the data processor regarding the adoption of necessary measures to guarantee the security of personal data is not an obligation of result but of means, without the infallibility of the adopted measures being required. It is only required to adopt and implement technical and organizational measures that, according to the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow avoiding their alteration, loss, unauthorized processing or access."

On this, it specifies that "It is not enough to design the necessary technical and organizational means; their correct implementation and appropriate use are also necessary, so that it will also be liable for the lack of diligence in their use, understood as reasonable diligence considering the circumstances of the case."

In the case being examined in this sanctioning procedure, it is considered that adequate security measures to the risk in the rights and freedoms of the data subjects were not implemented, even if there had not been a breach of personal data.

As has been stated, (...).

On the other hand, (...).

In conclusion, a violation of Article 32 of the GDPR would be evidenced by the lack of adequate security measures in the procedure established by the banking entity.

- In relation to the security measures (...):

- o (...), the date on which the breach of personal data occurred.

- o On February 1, 2021, (...), an update of a client's data and a transfer from another client to a third party were made.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

76/121

o

Each of the affected banking operations had to have (...).

o

(...).

o

(...).

o

(...).

□

In relation to security measures (...):

o

(...).

o

(...).

o

(...).

o

(...).

o

Upon examining the procedure implemented in the entity, it is noted that there were no adequate security measures in the system (...).

VII

Analysis of the Violation of Article 25 of the GDPR

On this occasion, the case subject to this sanctioning procedure will be analyzed from a third angle or different perspective: whether the principle of privacy by design was respected.

It will be examined in four sections:

1. Content of the principle of privacy by design and the internal conditions for its compliance.
2. Analysis of the design of the procedure that articulates the processing of documents submitted by the interested parties of CaixaBank that affect the protection of personal data.
3. Design of the system for generating the saving path (also referred to as path HCP) of documents related to CaixaBank's banking operations.
4. Analysis of the design of what happens in the system when an error code is generated after deactivating the archiving versioning.

1. Content of the principle of privacy by design and the internal conditions for its compliance.

As highlighted in the legal basis III:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

77/121

1. Article 25 of the GDPR is based on the need to take into account a series of elements:

☐

State of the art

☐

Cost of implementation

☐

Nature, scope, context, and purposes of the processing

☐

Risks posed by the processing to the rights and freedoms of natural persons.

2. It imposes an obligation on the controller, who determines the purposes and means of the processing, giving, in this case, special relevance to the means.

3. The controller must apply, both when determining the means of processing and at the moment of the processing itself, appropriate technical and organizational measures (for example, pseudonymization), designed to effectively apply the principles of data protection and integrate the necessary guarantees into the processing.

4. This pursues a dual purpose:

☐

To comply with the requirements of the GDPR

☐

To protect the rights of the interested parties.

The GDPR aims to achieve the protection of the rights of the interested parties through the application of its provisions. Therefore, the focus must always be directed towards the identification and assessment of risks to the rights and freedoms of the interested parties, with the subsequent adoption of technical and organizational measures of all kinds aimed at preventing their materialization. In this framework, actions must be preventive and not reactive, as otherwise the data controller will not be able to anticipate the materialization of risks.

- a) Focus on the risks to the rights and freedoms of the interested parties.

Thus, Article 25 of the GDPR refers to the "Risks posed by the processing to the rights and freedoms of natural persons."

If the approach taken by the company or organization is not oriented towards the risks to the rights and freedoms of the interested parties but rather towards the risks to the company or organization itself,

not only will effective protection for the interested parties not be sought (since where you do not look, you do not see), but Article 25 of the GDPR will be violated, and ultimately, the objective that data protection regulation aims to achieve will not be met.

Based on this, it is evident that the risk perspective that CaixaBank has managed in the case analyzed in this sanctioning file has not been correct. It has not been focused on the interested parties (who are all the natural persons whose personal data it processes, as a controller or as a processor, and not only regarding its clients or employees) but rather on the risks to its own organization.

This lack of appropriate focus resulted in CaixaBank not clearly identifying those affected and that each time a different affected party is considered:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

78/121

1. At first, (...).

2. In a second instance, (...).

3. (...).

If the interested parties or affected subjects are not correctly identified (a crucial piece of information for making a proper identification and assessment of the risks that the processing entails for their rights and freedoms), it becomes impossible to ensure adequate data protection based on the content of Article 25 of the GDPR. This can be verified through the various writings of CaixaBank:

- (...).

- (...).

- (...).

- (...).

On the other hand, another example of the lack of a risk-based approach to the rights and freedoms of individuals and the non-compliance with Article 25 of the GDPR is the absolute absence of such an approach mandated by the GDPR in the procedure presented by CaixaBank in its allegations to the proposed resolution for the purposes of its defense, regarding the resolution of the complaints filed by its clients, which will be examined in detail later.

Moreover, we are unaware of the date of implementation of this complaint resolution procedure; it does not have a focus on the protection of personal data but rather has a banking, insurance, and consumer perspective. It is extremely significant that in the procedure presented, the term "personal data" or "personal data protection" does not appear even once.

Thus, on one hand, it is a clearly inadequate procedure for protecting the rights and freedoms of the interested parties, as no consideration of the risks to the rights and freedoms of the interested parties in data protection is taken into account by the entity.

But, on the other hand, and more seriously, if this is the procedure they present to demonstrate compliance with data protection regulations, if this is the procedure they have, then there is really no procedure to resolve complaints regarding data protection.

b) Proactivity and not reactivity.

Privacy by design (hereinafter, PBD) requires being proactive (as highlighted in the AEPD's Privacy by Design Guide) and not reactive. If the company or organization acts reactively, as has happened in this case, there is no PBD.

As an example, (...).

(...).

CaixaBank has been acting reactively, not proactively, addressing the issues, both of the complaint and of the designed procedures, that were required or raised, not acting in a systemic, foresighted, and comprehensive manner, as PBD requires. This has occurred because CaixaBank had not implemented data protection by design and by default. It did not have an established protocol that would allow it to address these cases. It had defined its procedures from an internal perspective focused on business and not on personal data and the consequences that the lack of confidentiality, integrity, or availability could entail.

Returning to the specific case of the complaint, which has been analyzed regarding the procedure, for example, the following aspects reflect this:

- The proof of the update of contact data carried out by the complainant (...) was not available (...).
- (...).
- (...).
- (...).
- (...).

CaixaBank's reactive action goes beyond the specific case since, as we have seen, it has also changed issues related to the procedure it had established regarding the storage route and the incidence of leading zeros. All of this is a consequence of the detection of this flaw in the design of the procedure by the AEPD and highlighted in the initiation agreement.

Furthermore, it has not anticipated a procedure for resolving complaints regarding data protection, which should have been thought out, planned, and implemented before any data protection complaint was filed by an interested party. That is to say, instead of anticipating ex ante actions that protect the personal data of the interested parties, it has moved to ex post actions using a procedure intended to resolve complaints that have nothing to do with the protection of personal data, thus determining the non-compliance with Article 25 of the GDPR.

CaixaBank does not have an adequate procedure for managing complaints from interested parties regarding data protection (it is configured as a general customer service without anticipating issues related to data protection), so when they receive any complaint, they limit themselves to applying the established procedure for resolving customer complaints related to financial, insurance, and consumer aspects.

This is evident not only from the simple reading of this document, which lacks a date and signature, but also from the undeniable fact that there is no reference whatsoever to the data protection issues raised.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
80/121

neither the GDPR nor the LOPDGDD (although other applicable regulatory provisions are cited for such procedures) mentions the expression "personal data" or "protection of personal data" even once. Currently, based on what was presented during the allegations phase to the proposed resolution, they only have a customer complaints procedure regarding financial matters, insurance, and consumer issues, and not a procedure concerning data protection. Therefore, the interested parties remain unprotected. This is not the approach pursued by the GDPR, which requires proactive actions from the data controllers, as established in the principles (Article 5.2 of the GDPR).

2. Analysis of the design of the procedure that articulates the processing of documents submitted by the interested parties of CaixaBank that affect the protection of personal data.

In relation to this issue, the GDPR grants companies a wide margin of freedom when configuring their internal organization. It does not impose a specific way in which they must internally process the documents they receive from interested parties regarding personal data protection. However, it requires that their actions are respectful at all times of what is provided in that Regulation.

To this end, it is necessary for the designed procedure to be effective. It must give preference or priority to the claims, complaints, questions, etc. raised by the interested parties regarding data protection. We must not forget that this is a fundamental right that must be protected by the data controller, as stated in Article 25.1 of the GDPR in fine.

The AEPD does not doubt that CaixaBank must address daily other issues unrelated to personal data protection raised by its clients. However, even under these circumstances, it must ensure that the documents and claims related to personal data protection are duly addressed, in an agile and correct manner.

The lack of a management procedure for claims from interested parties regarding data protection is

evidenced in the proposed resolution and corroborated in the resolution in light of the procedure provided by CaixaBank along with the allegations to the proposed resolution for the purposes of its defense.

It is unknown, as CaixaBank does not indicate, since when this procedure has been in effect, since when it has been public, as well as who approved it and according to what parameters.

However, the truth is that, for the purposes of providing its defense, this is the procedure they indicate they have established to resolve the claims of the interested parties regarding data protection.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
81/121

The aforementioned procedure regulates both the processing of claims from CaixaBank customers and the Customer Service of said financial entity to resolve claims related to finance, insurance, and consumer matters.

There is no doubt about the suitability of this procedure from a financial perspective, relating to insurance or consumption. However, it is not adequate from the standpoint of processing claims or writings related to the protection of personal data, for a simple reason: personal data protection has not been considered when drafting and designing the aforementioned procedure.

The regulatory references in Article 1 relate to the financial, insurance, and consumer litigation sectors, not to the protection of personal data. There is no mention of the GDPR, nor the LOPDGDD, nor personal data, nor the protection of personal data.

There is one article (Article 22) related to the Participant and Associate Ombudsman, but it is striking that in the claims processing procedure, the Data Protection Officer of CaixaBank is not mentioned at any point. There is also no provision for communication to the Data Protection Officer either prior to or after the receipt of a data protection claim from an interested party.

Articles 2 letter f) and 6 letter c) refer to the Claims Services of the supervisors (the Bank of Spain, the National Securities Market Commission, and the Directorate General of Insurance and Pension Funds). The AEPD is not mentioned at any point.

In Article 11 (Deadline for resolving the claim), it is highlighted that, in case of disagreement with the resolution of the Customer Service, or if no ruling is issued within the stipulated deadlines, the claimant may turn to the Claims Service of the relevant supervisors (referring to those mentioned in the previous paragraph). From this perspective, given that it is the procedure they are applying, it is understandable that, for example, in the specific case that originated the investigation and subsequent processing of this file, CaixaBank's response letter dated November 10, 2021, referred the claimant to the Bank of Spain, instead of to the AEPD, which is the competent authority in matters of personal data protection. Subsequently, the Bank of Spain sent the claim to this Agency.

Article 7 regulates the configuration of the Customer Service, highlighting in its section 4 that necessary actions must be taken so that the personnel assigned to it have adequate knowledge of the regulations on transparency and protection of customers of financial services. At this point, it is striking that there is a total absence of reference to the protection of personal data. This personnel will be responsible for detecting and processing the claim; in addition to the indicated knowledge, they must have knowledge related to the protection of personal data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

82/121

In conclusion, this customer claims management procedure in financial, insurance, and consumer matters is not an adequate procedure regarding data protection for managing the claims of interested parties who, in themselves and in the terms of the GDPR, have not been considered at any time and whose risks are not present, nor identified, nor assessed in said procedure.

Next, we will review the procedure submitted and applied by CaixaBank to address claims regarding data protection, and to be more illustrative, we will rely on the claim that was the origin of the investigation:

1. (...).
2. (...).
- (...):
- a. (...).
- b. (...).
- c. (...).
- d. (...).
3. (...):
- (...).

The GDPR has represented a shift from a reactive conception to a proactive philosophy, reflected in Article 5.2 of the GDPR.

As highlighted earlier, the company or organization can configure its procedure for processing writings submitted by CaixaBank customers that affect the protection of personal data as it deems most suitable for its organization, but it is reiterated that it is important that it be adequate, effective, and guarantees compliance with the provisions of the GDPR and the LOPDGDD.

This procedure should be a channel that ensures that, for example:

1. Any writing regarding data protection is detected as soon as it is submitted.
2. The content of the same is communicated to the Data Protection Officer of the company or organization (DPO), to ensure that they can exercise their function as a qualified advisor from the very beginning.
3. The processing aligns with what the interested party has raised.
4. The issue or issues raised in the writing are resolved promptly and effectively.
5. There is subsequent control of the adequacy and effectiveness regarding the management of the claim in matters of data protection, as well as follow-up on the claim.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

83/121

Reviewing, where applicable, the designed procedure, in order to adopt technical and organizational measures of all kinds that allow for adequate compliance with the requirements of the GDPR and effective protection of the rights and freedoms of the data subjects.

In conclusion, the examination of the procedure established by CaixaBank to address issues related to customer complaints, which has been presented along with its allegations to the proposed resolution and applies to the claims of data subjects regarding data protection, shows that it is not focused on the risks to the rights and freedoms of the data subjects. It also does not meet minimum guidelines, such as those outlined in the previous section, for it to be adequate and effective. Furthermore, the procedure applied by CaixaBank for data protection claims (which relates to financial, insurance, and consumer claims) does not provide for any type of subsequent control system that allows for the detection of possible errors in the previous phases in order to correct them as soon as possible.

The chosen design would not respect privacy by design and constitutes a violation of Article 25 of the GDPR.

As highlighted in legal basis III, the investigation of the personal data breach by the AEPD has revealed an internal problem within the organization, which is sanctionable even in the event that no personal data breach has occurred.

It cannot be assumed that we are dealing with an isolated case, as there is no internal procedure to resolve claims from data subjects regarding data protection. For example, the processing of the complaint from the claimant dated August 12, 2022, in which they expressed their desire to have available the proof of the update of contact data carried out on February 1, 2021 (...), meets the same fate as the complaint from (...), despite being the second complaint made on the same issue, also

concerning the processing of personal data.

CaixaBank makes an allegation regarding the fact that the proposed resolution conducts an analysis of the design of the procedure that governs the processing of documents submitted by CaixaBank customers that affect personal data protection.

In relation to this issue, in summary, it highlights:

"The AEPD, in a novel manner in the proposed resolution, and probably upon appreciating the possibility that it could be considered that in this case there is a clear *bis in idem*, states without providing evidence in this regard, that CAIXABANK lacks an adequate procedure for addressing its customers' claims regarding data protection, even though it only has one case in which this procedure has not been complied with. And all this without once requiring my represented party about the existence of such a procedure. Thus, the doctrine established in the ruling of the National Court of December 23, 2022, is violated, turning what occurred in a specific case into a systematic violation, even though such a circumstance is not proven."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

84/121

In relation to the "novel form" referred to by the responding party, the initiation agreement already indicates the existence of a possible infringement of Article 25 of the GDPR due to the lack of data protection by design and by default, arising from the indications and evidence obtained during the preliminary investigation proceedings.

Furthermore, for greater clarity, the aforementioned agreement refers to the possible infringement of Article 25 of the GDPR, where legal basis VII warned: "Therefore, in accordance with the evidence available in this initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction (...)."

As a consequence of the instruction of the procedure and in light of what has been established in the proven facts, the existence of an infringement of Article 25 of the GDPR is confirmed in relation to the management procedure for complaints from data subjects, due to its absence and the subsidiary application of a procedure designed for another purpose (financial, insurance, and consumer sectors). Moreover, the Constitutional Court (hereinafter TC) has indicated that "the essential content of the constitutional right to be informed of the accusation refers to the punishable facts attributed to the accused" (STC 95/1995). In contrast, and unlike what occurs with the facts, the TC, in Judgment 145/1993, warns that the communication to the alleged infringer of the legal qualification and the potential sanction to be imposed does not constitute the essential content of the right to be informed of the accusation. So significant is the notification of the constitutive facts of the administrative infringement that the TC has declared that the requirements of Article 24.2 of the CE are fundamentally satisfied with the mere communication of the alleged facts to enable defense against them (STC 2/1987 and 190/1987). In this regard, the Supreme Court, in its Judgment of March 3, 2004, states that "the primary purpose of the initiation agreement is to inform about the alleged facts and not about the legal qualification, which will be addressed by the resolution proposal." (The emphasis is ours).

The banking entity highlights that the assertion regarding the design of the aforementioned procedure has been made by the AEPD without providing evidence in this regard. This assertion is not shared. In legal basis VII (Analysis of the possible violation of Article 25 of the GDPR), this issue is analyzed in section 1, referring to the following aspects:

- Legal basis II (Complaint process).
- Proven facts eleventh, twelfth, thirteenth, and fifteenth.
- DOCUMENT NUMBER 1 submitted by CaixaBank on July 18, 2023, in response to the practice of evidence II.

Additionally, what has been established by the AEPD in the resolution proposal has been corroborated in light of the complaint procedure of CaixaBank's customers submitted along with the allegations to the resolution proposal.

All of the above evidences the lack of an adequate and effective procedure, protocol, or guidelines, respectful of the GDPR, both to identify and assess existing risks in data protection, which could prevent incidents from occurring.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
85/121

teeth that would infringe upon the rights and freedoms of the interested parties, and once these have occurred, attempt to process any possible claims (including their control and subsequent follow-up). This AEPD considers that the banking entity should review this procedure from a perspective focused on the protection of personal data or design a specific procedure; what matters is that there is a procedure and that it is effective and compliant with data protection regulations.

Furthermore, among other issues, which it must determine in accordance with its proactive responsibility, it should ensure that the human resources of the Customer Service of the banking entity have sufficient knowledge regarding personal data protection.

These recommendations are made considering that the responding party claims to manage a "huge volume of claims directed at CaixaBank, which only in terms of personal data protection (...), to which must be added (...)."

In its written allegations to the proposed resolution, the banking entity refers to a "(unfortunate) specific fact."

As indicated at the beginning of this legal basis, where you do not look, you do not see.

This is not a mistake or failure in the procedure; it is a lack of the same, which, as indicated, can be established from a differentiated procedure or not, a protocol, or guidelines that respect the rights and freedoms of the interested parties and are adequate to personal data regulations. The reality reveals the lack of that procedure designed by the organization (in this case, CaixaBank). This way of acting does not comply with the provisions of Article 25 of the GDPR.

As highlighted, the absence of an adequate procedure referred to can be reflected through the various actions that CaixaBank carries out.

The banking entity concludes its allegations to the proposed resolution regarding this point by referring to the Judgment of the National Court of December 23, 2022 (appeal 104/2021).

Firstly, the aforementioned judgment has been appealed in cassation.

Secondly, the fifth legal basis of the same responds to an allegation regarding the total disconnection of the object of the procedure on which the resolution was based and the claims made.

Such disconnection, as stated, would not exist in this case. Both the claim submitted by Mr. A.A.A. to the Conduct of Entities Department of the Bank of Spain on February 10, 2022, and his letter of August 12, 2022, are closely related to how CaixaBank addresses the documents submitted by its clients that affect personal data protection.

On the other hand, that section of the proposal does rely on elements of proof and evidence presented during the processing of the file, as has just been explained.

3. Design of the document saving route generation system (also called path HCP) related to CaixaBank's banking operations:

Before proceeding with this analysis, it is necessary to highlight that we would find ourselves (...).

(...).

As a result, the transfer receipt (...).

3.1. How the (...) is generated:

Next, we proceed to analyze the design of the system created by CaixaBank for (...).

Starting from the explanations about the (...) reflected in the proven fact forty-second, the following should be highlighted:

(...).

(...).

(...).

As can be observed:

1. (...).

2. (...)

-

(...).

-

(...).

3.2 (...)

-

CaixaBank had opted for (...)

It was possible for the coincidence of (...) in the same millisecond.

-

Regarding the random value, CaixaBank had (...)

(...):

(...).

-

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

87/121

3.3. Design of the system (...) currently in place:

☐

(...)

3.4 Probability of such

(...):

As reflected in the forty-eighth proven fact, CaixaBank considers that it is (...).

In the Diligence of July 18, 2023, which is part of the file, it is highlighted that:

“(…).”

In the Report requested by the Instructor of PS/00020/2023 in the context of the evidence practice dated July 18, 2023, prepared by the Inspector, the content of which has been reproduced in the fifty-fifth proven fact, it is highlighted:

“☐ (...)

CONCLUSIONS

(...)

In the written allegations to the proposed resolution, CaixaBank has made several allegations regarding the Inspector's report that has just been reproduced. In summary, it highlights:

“The assessment made by the Inspector in his Report, which is attached to the Proposal for Resolution, not only completely lacks rigor from the perspective of probability calculation, but is also inadequate, since it is based on (...) currently, without taking into consideration that only a small number of such operations generate documents and that the volume of activity of my client when the detected breach occurred was significantly lower than the current one, this figure having been provided by my client in response to the third evidence request made by that AEPD.”

Regarding these allegations, it should be noted:

Statistics is a branch of mathematics that facilitates approximations in order to try to determine what may happen in reality. In this sense, it is worth remembering that CaixaBank made an approximate calculation in the written allegations to the initiation agreement (considering the time frame in which banking activity could be greater (...)).

The Inspector, for his part, performed a very simple calculation of (...). This calculation could also have been performed using much more complex mathematical formulas, which does not detract from the validity of the mathematical calculation made.

In order to discredit the calculation made by the Inspector, CaixaBank has used arguments whose content is not shared at all and, at times, may lead to confusion.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

88/121

For example, in its written allegations to the proposed resolution, the claiming party highlights, in relation to the Inspector's report of July 18, 2023:

“(iii) it has used data that does not match the date on which the breach referred to in this file occurred, despite that information having been requested by the Instructor; and”

Well, let us take as a reference that the date of the personal data breach occurred on February 1, 2021.

Thus, in the context of the evidence practice, after sending CaixaBank the evidence practice III, a report is requested from the Inspection Coordinator dated July 17, 2023, in light of the information previously provided by CaixaBank in the file.

We must emphasize that there was no information at that time about the number of transactions per second that were carried out at CaixaBank as of February 1, 2021, nor had it yet been provided to the file by the claiming party.

In fact, in the internal Note dated July 17, 2023, sent to the aforementioned Inspection Coordinator requesting a report, the following was indicated:

“(...)”

It is requested that, in light of the information provided by CAIXABANK, S.A. in this file, an urgent report be prepared regarding the probability that a (...) occurred.

It is also requested that it indicate whether that probability calculation could be applied to the number or average of operations per second corresponding to a date other than June 1, 2023.”

As can be seen, the request for the report is made in light of the information previously provided by CaixaBank in the file.

On the other hand, on July 18, 2023, the day the Inspector prepared his report, the certificate from CaixaBank indicating the number of transactions per second that were carried out at CaixaBank as of February 1, 2021, had not yet been received.

The mentioned certificate was signed by Mr. D. D.D.D. that same day (July 18, 2023) at 19:04:09 (as stated in the certificate itself). It was submitted to the AEPD Registry that same day at 19:47:02 and was registered the following day (July 19, 2023) at 09:24:39.

We find another example of these defense techniques when CaixaBank states that “only a part, and very small, of the operations that are carried out in the banking operations of CAIXABANK (...)”

On one hand, it should be noted that the “very small” amount referred to in the written allegations to the proposed resolution is completely indeterminate. Despite this, CaixaBank does not hesitate to assert in the written allegations to the proposed resolution:

“all these operations should have been excluded a limine from the calculation made by the inspector.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

89/121

On the one hand, it is a new example of how an attempt is made to minimize a risk. Thus, the responding party (...). The idea is conveyed that the risk is so small that it is almost nonexistent. Which, as we will see, is false.

CaixaBank now claims that (...) in that banking entity the risk is low. Even if that were the case, if among these operations there are transfers, as happens in practice, the daily volume of such operations at CaixaBank is very high. This is due, among other parameters, to the number of clients of the entity, one of the largest in Spain.

(...).

In this way, regardless of (...).

Second, because the system is poorly designed as it does not focus on the risks to the rights and freedoms of the interested parties, which means that, in any case, the risk is present regardless of (...). In any case, setting aside the defense techniques that have just been indicated, (...), as the responding party intends to imply.

The allegations regarding whether the Inspector's calculation was accurate or not cannot distract attention from the fact that this risk exists, whether to a greater or lesser extent. For example, one can cite the case of the complaint filed with the Agency in which it is evident that we are not dealing with a mere possibility, as the breach of personal data materialized in practice.

In relation to this issue, the Guide for the notification of personal data breaches highlights the following: "Regarding probability, it is not about determining the probability that the personal data breach will materialize, because obviously in this situation the breach would have already materialized, but rather determining whether there is a possibility that the consequences will materialize with a high or very high level of severity. To determine this, the technical and organizational measures applied before the breach occurred and the actions taken afterwards to prevent the damage from materializing must be taken into account." (the underlining is ours)

Returning to the design of the system by CaixaBank, a banking entity of its relevance, it had both the capacity and sufficient means to have taken actions aimed at ensuring that the design of the system it opted for was robust:

☐

(...).

☐

(...).

On the other hand, (...). In this case, we do not know if on February 1, 2021, the system was at peak load when the personal data breach occurred, but what we do know for sure is that this personal data breach took place.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

90/121

CaixaBank tries to convince us that the probability of a personal data breach occurring was infinitesimal, which could lead the responding party to assert that the personal data breach was unforeseeable and be exempted from all liability.

If we start from the design that CaixaBank opted for, it cannot be said that the personal data breach was unforeseeable.

1. (...)

2. (...)

3. (...)

Based on these three elements, it cannot be said that the personal data breach was unforeseeable.

To what has already been stated, a fourth element should be added:

4. (...)

In conclusion, the four elements presented show that the personal data breach was not unforeseeable. What can be appreciated is a clear lack of foresight on the part of the banking entity when designing its system.

(...).

These are issues that are pointed out and invite analysis by the banking entity.

4.

Analysis of the design of what happens in the system when an error code is generated after the archiving versioning has been deactivated:

CaixaBank states that the solution to the problem generated by the personal data breach (...).

In test practice II, CaixaBank was requested (...).

CaixaBank has indicated that (...).

4.1

Evolution of the relative design

(...):

We are going to analyze (...). To do this, the procedure used by the banking entity will be analyzed, through the actions carried out and, as an example, the complaint filed with the Agency will be used:

4.1.1. Time period during which the

(...)

The two banking operations (in the analyzed case, updating the contact details of the claimant and transfer of D. C.C.C.) were executed and recorded. However, (...).

(...), resulting in the personal data breach.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

91/121

(...).

4.1.2. Period Covered

(...).

Period following the (...).

First document (in our case, the update of contact details). (...).

Second document (in our case, the transfer) (...).

The solution provided by CaixaBank (...):

A. (...).

CaixaBank states that the client would have the proof of the update of contact details (...).

With this solution, the proof of the update of contact details was generated, but the client could not access it (...).

The banking entity is transferring a problem arising from its internal operations to the client, who cannot access the proof of the operation just performed (...).

The adopted design is not transparent. (...)

Secondly, the fact that the client cannot access the proof of the update of contact details (...).

Apparently (...), but it must be taken into account that it can generate confusion for the client, who does not know when the update of contact details actually occurred. On the other hand, immediacy, in terms of the availability of the proof, may be crucial in cases where the client needs to prove the modification made to third parties or to the entity itself.

Therefore, the design was not suitable as it was not based on a client-centered approach, focusing on the risks to their rights and freedoms and their effective protection. It solved a problem for the banking entity but generated the aforementioned disadvantages for the client.

B. In the case of (...):

(...).

In this case, a design was chosen that transfers the problem of the banking entity to the client.

In this instance (...).

The inspector in his report of January 18, 2023, highlighted:

(...).

The opinion of the Inspector is shared, with a solution that places the burden on the client, who (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

92/121

The client may need to credibly and urgently prove that they have made such a transfer. Currently, it is not so easy to be attended to at a branch of a banking entity.

As in the previous case, it is also not considered a transparent design, (...).

4.1.3.

(...):

Regarding the first document (...).

It should be noted that this design is better than the previous one from the client's perspective.

(...).

In conclusion, CaixaBank's actions in this area are not ideal, based on the perspective of Article 25 of the GDPR.

As a consequence (...).

Subsequently, when (...).

The adoption of this measure was positive for the future (...), but not for a breach that had occurred in the past (...).

Proof of this is that (...).

Regarding the design, at the time the personal data breach occurred, it was not suitable.

In the second phase, a design is observed that is more focused on the risks of the organization and its problems than on the risks to the client.

In the third phase, the system has been improved, (...).

Analysis of other allegations made by CaixaBank in its submission of February 20, 2023:

In its submission of allegations dated February 20, 2023, CaixaBank highlights:

(...)

(...).

In the document of December 13, 2022, prepared by CaixaBank in response to the Inspector's second request, reproduced in the twenty-seventh proven fact, it states that (...):

"(...)."

In the (...) the following desirable properties are listed in a (...):

(...):

- (...)

- (...).

- (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

93/121

- (...).

- (...).

- (...).

- (...).

- (...)

Continuing with the analysis of the allegations made regarding the initiation agreement, along with the document dated February 20, 2023, CaixaBank provides numerous documents. Two paragraphs referencing these are reproduced as follows:

"(...)."

It is necessary to clarify that, while it is positively assessed that CaixaBank has a normative corpus regarding security, the existence of such a corpus does not automatically guarantee compliance by the banking entity with the provisions of Article 25 of the GDPR, especially when compliance with this provision requires technical and organizational measures of all kinds and not just security measures. It is essential to analyze whether its organization operates adequately on a daily basis, in light of the provisions of that article. It is necessary to verify that the internal procedures are well designed and

allow for the protection of the numerous personal data that are processed daily by this financial entity, with sufficient guarantees.

Continuing with the analysis of the allegations document regarding the initiation agreement of February 20, 2023, CaixaBank highlights that:

“(…)”

It is not disputed that this is the case, but the methods or means employed must be effective and adequately fulfill their role of protecting the personal data being processed, in compliance with both the GDPR and the LOPDGDD.

Next, the allegations document regarding the initiation agreement of February 20, 2023 states:

“In other words, the obligation to comply with Article 25.1 of the GDPR is not conceived by the EDPB as an obligation of result, in the sense that the results derived from its implementation can be considered compliant with what is established in the GDPR, but rather as an obligation of analysis, so that if a data controller has adequately carried out the analysis, even if the result may be deemed erroneous by the supervisory authority, there would not be a violation of the principle of Privacy by Design, but rather, if applicable, of one of the principles established in Article 5 of the GDPR or of the norms in which those principles are specified.

To put it graphically, and as previously pointed out, it is possible that the performance of the analysis of the processing carried out by a controller results in a scope of compliance with the duty of transparency that is subsequently not considered sufficient by the supervisory authority, understanding that the information provided to the data subjects is not sufficient. However, this would not imply that the entity in question had failed to fulfill its obligation to adopt the necessary measures for compliance with the principle of transparency, but rather that this principle would not be considered fully respected by the AEPD. That is to say, the result of that assessment would be a violation of Articles 5.1 a), 13, and 14 of the GDPR, but not a violation of Article 25. There would be no grounds to sanction the lack of privacy by design, but rather the alleged non-compliance with the principle or the norm in which it is specified.

And this circumstance is what applies in the present case: my client has fully analyzed and assessed all the measures that needed to be adopted to ensure compliance with the principles established in Article 5 of the GDPR.

A different matter, denied by my represented party, will be whether the AEPD considers that one of the security measures adopted by my client is insufficient.

In that case, it may be appreciated that adequate measures have not been adopted, but in no case can that alleged insufficiency be considered a non-compliance with the provisions of Article 25.1 of the GDPR.”

The interpretation presented by CaixaBank, which minimizes the scope of Article 25 of the GDPR to such an extent that it is not compatible with what is established in the GDPR, is not shared. As previously highlighted, the Regulation establishes a complete system aimed at fully guaranteeing the rights and freedoms of citizens.

Although in the allegations document it is located in the section related to Article 32, as it is more linked to design, the following allegation will be analyzed in this section:

“(…).”

It is not agreed that the concurrence of factors was unpredictable as previously stated.

If in an entity the size of CaixaBank, with an operational volume that can reach an average of (...), it is designed (...):

☐

(...).

☐

(...).

(...).

(...), it should be anticipated that this coincidence of (...) could occur, in order to prevent a personal data breach from occurring in practice.

CaixaBank now states in its allegations to the proposed resolution that not all banking operations generate documents, without even providing an approximate percentage of them. As previously

indicated, it attempts to minimize an existing problem in the effort to be exonerated from all responsibility.

In the case analyzed, (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

95/121

(...).

No provision is appreciated. Furthermore, it demonstrates that CaixaBank is accepting and attempting to correct the deficiencies detected and communicated by this Control Authority. It is not a proactive action, as required by Article 5.2 of the GDPR, but rather a fundamentally reactive attitude. Problems are being resolved as they are detected, and gaps are being filled as the entity becomes aware of them.

In conclusion, an infringement of Article 25 of the GDPR would be established due to the lack of privacy by design in the procedure established by the banking entity.

☐

Regarding the adequate and correct application of Privacy by Design as provided in Article 25 of the GDPR:

o

The banking entity's approach to risks is not in line with the Privacy by Design of Article 25 of the GDPR.

It does not focus on the risks to the rights and freedoms of the data subjects (clients or non-clients of the entity whose personal data they process) but rather on the risks to the organization.

o

CaixaBank's actions regarding the design of the procedures subject to this sanction and previously described have not been prior, thoughtful, and proactive at any time as mandated by Article 25 of the GDPR, but rather fundamentally improvised and reactive. Furthermore, even throughout this file, CaixaBank has not considered an ex ante situation.

☐

(...).

What is now designed (...).

☐

Regarding the (...) of documents related to CaixaBank's banking operations.

o

Regarding the system designed at the time of the personal data breach to achieve (...):

☐

(...).

☐

(...).

☐

(...).

(...).

☐

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

96/121

(...).

☐

(...).

□

(...).

Regarding the system designed after the personal data breach to achieve (...), it should be noted that modifications have been made to the system (as a consequence of the incidents detected by the AEPD and highlighted in the two information requests from the Inspector, the initiation agreement, and the requests for evidence) that are partial, reactive, and do not encompass a complete review of the system.

Regarding the probability of (...), it turns out that this probability is considerably higher than that calculated by CaixaBank (...).

Regarding (...):

o

(...).

o

(...).

o

(...).

VIII Alleged violation of the principle of proportionality

In relation to this issue, in the written allegations to the initiation agreement of February 20, 2022, it is indicated:

“Thus, it is necessary for the Sanctioning Body to evaluate that in this case we are dealing with a single complaint made by a single client of my client, not related to their own data, but to that of a third party and related to a specific and determined situation, the access to a document foreign to the Claimant, and it is also the case that two of the infringements established by the GDPR for the mentioned conduct are included in its Article, 83.4 of the GDPR.

However, the AEPD does not hesitate in this case to impose three sanctions on my client, which are subsumable into one another, for a total amount of five million euros, resorting to completely generic criteria for determining the amount of the sanction, which my client flatly rejects. At the same time, again, my client wishes to highlight how the criteria used for the aggravation of one of the infringements are literally reproduced regarding the others, which only serves to highlight the concurrence that the AEPD itself appreciates in its Agreement regarding the three infringements, where the arguments are perfectly interchangeable among its legal grounds VI, IX, and XII.”

Responses have already been given to the allegations regarding the alleged violation of the principle of non bis in idem and the medial concurrence.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

97/121

The written allegations regarding the resolution proposal reiterate that it concerns a single complaint:

“My client has not had any other complaint related to similar facts that have occurred, despite the enormous volume of complaints that it processes, and likewise, the AEPD has not been aware of any other complaint of similar characteristics. All of this only highlights that neither the likelihood of the circumstances of the case is as claimed by the Agency nor is it possible to consider potential harmed parties among all CAIXABANK customers.”

Regarding the first paragraph of the allegation against the initiation agreement and the paragraph related to the resolution proposal that have just been reproduced, they show the underlying problem that has arisen in this procedure. CaixaBank believes that the entire content of this file reduces to a single complaint, which affects only one customer.

Moreover, what is claimed in this specific case affects two Caixa customers and a third party, and not just one customer; the operations established by Caixa as the data controller affect all its customers. What has been stated in the previous legal grounds reflects that, at the time the personal data breach

occurred, there were significant deficiencies both in security measures and in aspects related to design within that banking entity. And all of this has been determined based on the complaint filed, revealing significant deficiencies in the procedure established by the banking entity.

The AEPD has been aware of these problems, which are sanctionable in themselves (even without a personal data breach), as a consequence of the investigation into a personal data breach, which has brought them to light.

These deficiencies are structural problems that affect the financial entity as a whole. At the moment when the financial entity (...) (proven fact twenty-fourth), it should have paused to consider the ultimate causes of the (...) that had occurred and its scope. Such an analysis would have allowed it to determine the appropriate measures that needed to be adopted for (...), in order to ensure adequate protection of the personal data of its customers.

In contrast, initially, it did nothing. It considered that (...), was sufficient. Subsequently, when the AEPD began to investigate and make information requests, it adopted measures reactively and often improvised, (...).

Furthermore, it should be noted that Article 83 of the GDPR states that:

“Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case (...).”

It is also noteworthy that according to the “Guidelines 04/2022 on the calculation of fines under the GDPR” Version 2.0 Adopted on May 24, 2023:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

98/121

“139. Therefore, the supervisory authority will verify that the amount of the fine is proportional both to the severity of the infringement and to the size of the company to which the entity that committed the infringement belongs, and that the imposed fine will not exceed what is necessary to achieve the objectives pursued by the GDPR.” (the underlining is ours).

Thus, the fine will be proportional in relation to the severity of the infringement in the specific case, examined in the administrative resolution, considering all relevant judgment elements in the specific case in relation to the provisions of Article 83.2 of the GDPR, including the size, turnover, and viability of the company in question.

Furthermore, the fine must be deterrent, in order to discourage the commission of a new infringement and encourage compliance with the GDPR.

In this regard, Guidelines 04/2022 establish that:

“143. A fine is deterrent when it prevents a person from infringing the objectives pursued and the rules established by Union Law. What is decisive in this respect is not only the nature and level of the fine but also the likelihood that it will be imposed. Anyone who commits an infringement must fear that the fine will indeed be imposed. Here, there is an overlap between the deterrent criterion and the effectiveness criterion.” (the underlining is ours).

Regarding the infringement of Article 5.1 f) of the GDPR, said Regulation in its Article 83.5 provides:

“5. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;” For its part, regarding the infringements of Articles 25 and 32, which have their own entity, as indicated in Recital III, Article 83.4 of the GDPR provides:

“4. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to

a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;"

Given the above, it cannot be considered that any of the three sanctions (a fine of 2,000,000 euros, as a consequence of the infringement of Article 5.1 f) of the GDPR, a fine of 1,500,000 euros, as a consequence of the infringement of Article 25 of the GDPR, and a fine of 1,500,000 euros, as a consequence of the infringement of Article 32 of the GDPR) are disproportionate. In addition to the entity's turnover, all of them comply with the limits of Articles 83.4 and 5 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

99/121

Regarding the amount of the sanction, on CaixaBank's own website:

In the written allegations to the proposal for resolution, CaixaBank states:

"(...) it is necessary to take into account that the imputations directed against my represented party are based on a premise, (...).

Taking this premise into account, although, as indicated, CAIXABANK considers that all of this undermines its liability for the sanctions referred to in the Proposal for Resolution, my client believes that, at the very least, its responsibility in this case would be greatly diminished."

In view of the content of this resolution, it cannot be stated that all the imputations directed against CaixaBank are based on the calculation made by the Inspector on July 18, 2023.

In the legal basis VII (Analysis of the violation of Article 25 of the GDPR), the (...) has been highlighted, as well as other deficiencies from the design perspective, a circumstance that in no case would justify the enormous reduction of the amount of the sanction sought by CaixaBank. Regarding the other two infringements (Article 5.1.f) and Article 32 of the GDPR), the allegations made by CaixaBank to the proposal for resolution do not include any element that leads to the reduction of the sanctions reflected in the proposal for resolution.

Furthermore, CaixaBank alleges the following regarding the initiation agreement:

"• Finally, the Initiation Agreement, again reproducing literally its reasoning in legal bases VI, IX, and XII, states that the sanction should be aggravated as a consequence of the connection of my client's activity with the processing of data. Regarding this point, it is necessary, first of all, for the AEPD to again take into consideration the turnover or traffic of my represented party in each of the aggravating factors adopted.

Thus, in the first of them, this circumstance is taken into account to reinforce the potential impact of the facts (without prejudice to the fact that, as mentioned, a potential impact is not sanctionable under the GDPR, such and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

as stated by the National Court); at the same time, regarding negligence, my client's conduct is aggravated by the understanding that due to their sector of activity, they must be required to exercise special diligence; finally, it is considered that my client's business activities are linked to the performance of treatments, which should imply this triple aggravation derived from this fact. That is to say, in the opinion of the AEPD, when a financial entity commits an alleged infringement, its conduct must be viewed as triply affected by the mere fact of its belonging to the financial sector, which can hardly be considered in accordance with the principle of proportionality."

In relation to this issue, the written allegations to the proposed resolution highlight:

"Regarding the aggravating factors appreciated, my represented party can only reiterate that it is not possible to establish the a priori assumption that any infringement of data protection regulations must be increased, if not multiplied, in terms of determining the amount of the sanction in cases where the accused belongs to the financial sector and is a large company, on the grounds that such circumstance, by itself, aggravates the negligence in their actions and also determines, solely by the sector of activity of the accused, an increase in responsibility. My represented party, on the contrary, could also indicate that the incident that occurred not only had a minimal probability of occurring, but also represents a single case among the (...), which should result in a mitigation, and not an aggravation of the sanctioning reproach directed against it."

The allegation made is not shared. As previously indicated, in this file, three differentiated infringements would have been committed (Article 5.1 f), Article 25, and Article 32 of the GDPR).

In each of these distinct infringements, it is possible to consider as an aggravating factor the fact that CaixaBank is a large company that carries out the daily processing of an enormous volume of personal data. In this sense, the written allegations to the proposed resolution state "represents a single case (...)" and in another section adds "the huge volume of claims directed at CaixaBank, which in terms of personal data protection in the year 2022 were (...), to which must be added a total of (...) exercises of rights."

In view of the enormous volume of data processed by this banking entity, the content of the Judgment of the National Court of October 17, 2007 (rec. 63/2006) is recalled, in which it is emphasized that:

"when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

It is not the same for an identical infringement to be committed by a large entity, such as CaixaBank, which claims to carry out "(...)" of personal data processing, with the possibility of affecting the rights and freedoms of a very high number of individuals, than by a small self-employed person. Thus, the fine arises from the individualization of the infringement, as provided for in Article 83 of the GDPR.

In the written allegations to the proposed resolution, CaixaBank highlights:

"(...) my represented party considers it necessary to reiterate what has already been indicated in its allegations to the Initiation Agreement: the AEPD in its Proposal for Resolution

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

101/121

This section merely applies the elements that have been taken into account for the determination of the concurrent aggravating factors in the present case for the application of the sanctioning type, applying them both as elements of the type and as aggravating factors thereof.

It is not observed that elements contained in the type of the sanctioned infractions have been considered as aggravating factors. What can indeed be considered as such would be circumstances that concur in the proven facts and that endow them with greater severity, such as, for example, the duration of the infraction. An example is the lack of availability of the proof of the update of contact data by the claimant, which lasted until (...), as reflected in the tenth proven fact, with the consequent lack of availability of all the personal data of the claimant that appears therein.

On the other hand, continuing with the analysis of the allegations to the proposed resolution, in CaixaBank's opinion, it is illustrative of the supposed arbitrariness in which, in their view, the actions of

the AEPD incur, that the proposed resolution considers that the most significant infraction corresponds to the alleged violation of Article 5.1 f) of the GDPR, taking into account that said proposal refers solely and exclusively to the specific case being judged.

Furthermore, it is considered curious that the largest of the sanctions is applied to the alleged violation of the aforementioned article (art. 5.1f) of the GDPR), when the risk of confidentiality breach completely disappeared on ***DATE.1, almost two years before the initiation of the sanctioning procedure.

CaixaBank understands that the AEPD takes a specific case to draw a consequence that, in their opinion, has not been substantiated in any way and considers that this case extends to a supposed systemic situation.

In response to this allegation, CaixaBank's conduct has constituted a clear and serious violation of the principle enshrined in Article 5.1f) of the GDPR.

Article 83.2 of the GDPR provides for the necessity to descend to the specific case, considering the concurrent circumstances that are present and that determine, in this case, the greater severity considered by the AEPD in relation to the violation of Article 5.1.f) of the GDPR.

First, it is necessary to highlight that the fine amounting to 2,000,000 euros does not correspond to a single breach of personal data, but to two: one consisting of a loss of confidentiality and another for loss of availability.

Moreover, regarding the breach of personal data due to loss of confidentiality, it is of particular severity not only the disclosure to a third party (the claimant) of personal data of two individuals but also the entire time during which the claimant had at their disposal the proof of a transfer with the personal data of two individuals (...), which increases the risk of suffering harm to the rights and freedoms of those two individuals, among others, potential identity theft. Once personal data leaves the control of the data controller, those who have access to it may, although they should not, share, disseminate, or use it, increasing the risk to the rights and freedoms of the data subjects due to, for example, the indiscriminate dissemination that can occur through new technologies.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

102/121

Also, regarding the breach of personal data due to loss of availability, it is unacceptable that the claiming party has been without access to the personal data concerning them in relation to the update of personal data for more than (...). The absolute loss of control and disposition of the personal data that concerned the claiming party for an excessively long period of time is of immense seriousness, especially when the responding party did not consider at any moment, until it was required by the AEPD in the practice of evidence I, to make available to the claimant (...) carried out on February 1, 2021.

Finally, we must emphasize that from the phase of transferring the complaint, through the preliminary investigation proceedings, the allegations to the initiation agreement, the phase of evidence practice, to the allegations to the resolution proposal, a constant has been maintained. CaixaBank has tried to minimize what has happened, to deny the existence of the risk (it claimed that the probability of recurrence of the breach was (...); it continues to deny that a breach of availability has occurred, throughout the processing of the file (...) evidently to the client of the third banking entity whom it has not even considered, even going so far as to assert that the risks arising from the processing have been reduced to zero with the simple (...).

This approach is completely contrary to Article 5.1(f) of the GDPR, which aims to ensure that the processing of personal data is carried out in such a way as to guarantee an adequate level of security for such data.

If one starts from a perspective characterized by trying to make believe that what has happened is not serious, when it indeed is, and denying the existence of the risk, when said risk still exists, it becomes impossible to guarantee that the processing is carried out in such a way as to ensure an adequate level of security for personal data.

IX General issues regarding the protection of personal data

Article 4.2 of the GDPR defines "processing" as: "any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of enabling access, comparison or interconnection, limitation, deletion or destruction."

In the present case, according to the provisions of this article, there is evidence of the processing of personal data, since CaixaBank, for the provision of its services as a financial entity, processes numerous personal data on a daily basis. Therefore, the responding party is obliged to comply with the obligations that, for the data controller, are established in the GDPR and in the LOPDGDD.

Article 4, paragraph 12) of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "any breach of security that results in the accidental or unlawful destruction, loss or alteration of personal data transmitted, stored or otherwise processed, or unauthorized communication or access to such data."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

103/121

In the present case, there is a personal data breach under the circumstances indicated above, categorized as a confidentiality breach. It should be noted that the receipt of a complaint regarding a personal data breach does not directly imply the imposition of a sanction, as it is necessary to analyze the diligence of the data controllers and processors and the security measures applied.

Among the principles of processing provided in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in paragraph 1.f).

Furthermore, Article 32 of the GDPR, relating to the security of processing, establishes the obligation of the controller and the processor to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk.

Finally, it is worth highlighting Article 25 of the GDPR, which regulates data protection by design and by default. This provision requires the data controller to apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures designed to effectively apply the principles of data protection and integrate the necessary safeguards into the processing, in order to comply with the requirements of the GDPR and protect the rights of the data subjects.

X Article 5.1.f) of the GDPR

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

In this legal basis, the content of legal basis V (Analysis of the violation of Article 5.1.f) of the GDPR in its entirety, detailing the reasons why the AEPD understands that, in the case examined in this sanctioning file, the content of Article 5.1.f) of the GDPR has been violated is understood to be reproduced.

XI Qualification of the infringement of Article 5.1.f) of the GDPR and qualification for the purposes of prescription

The aforementioned infringement of Article 5.1.f) of the GDPR would constitute one of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines," provides:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

“5. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the prescription period, Article 72 “Infringements considered very serious” of the LOPDGDD indicates:

“1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall prescribe after three years: those that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

XII Sanction for the infringement of Article 5.1.f) of the GDPR

It is considered that the infringement in question is very serious for the purposes of the GDPR and that it is appropriate to graduate the sanction to be imposed in accordance with the following criteria established in Article 83.2 of the GDPR:

The following circumstances are taken into account as aggravating factors:

Article 83.2 a) of the GDPR:

a) Nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected data subjects and the level of damage and harm they have suffered;

The legal basis II (Course of the complaint) reflects the prolonged period of time during which (...).

The fact that the complainant had access to said document during that extended period of time increased the risks to the rights and freedoms of the ordering party and the beneficiary whose personal data appeared in it (identity theft, etc.).

On the other hand, the personal data breach, which took so long to be detected (one year and four months after it occurred and as a result of the transfer of the complaint made by the AEPD) and resolved by CaixaBank, had a consequence that has caused harm to the complainant: (...) that had been made on February 1, 2021.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

In the case analyzed in this sanctioning file, the complainant updated their contact information, which consisted, as reflected in the proven fact two, of:

1. (...).

2. (...).

The importance of the mobile phone in the banking sector is undeniable, as it acts, among other things, as:

- A means through which financial entities contact their clients.

- An electronic device that allows for both inquiries and all types of banking transactions. Sometimes, it allows for the signing of documents related to banking operations, receiving information about expenses incurred, etc.

- It plays a key role as a security element when making online purchases (two-factor authentication). In fact, most clients use it to successfully complete such purchases.

(...).

As reflected in the legal basis II (Claim Process) (...).

CaixaBank states in its allegations that there has been no breach of availability:

"However, with due respect, the aforementioned breach of availability did not occur in practice: (...).

(...).

(...).

For all these reasons, and contrary to what is indicated in the Initiation Agreement, the breach that occurred corresponds to what my client indicated in the responses given to the requests made by that AEPD, and in no case is it a breach of availability."

The argument put forth by CaixaBank is not shared. The complainant has been affected by a breach of availability, (...).

The Fundamental Right to the Protection of Personal Data consists of a bundle of powers that the legal system grants to the interested party for the purpose of "guaranteeing that person control over their personal data, its use and destination, with the aim of preventing its illicit and harmful trafficking to the dignity and rights of the affected party," in the words of the Constitutional Court in its ruling 292/2000, of November 30, 2000, rec. 1463/2000.

Not only must the effective updating of contact data, a sort of right of rectification carried out directly by the client, be carried out, but it must also be justified to them. This is to ensure that they maintain true control over their personal data as explained earlier, especially if they need to react to the entity, for example, in the event of a potential lack of updating of their personal data (and the damages that could arise from this). As has been explicitly stated throughout the administrative resolution, the receipt contained all the personal data that the client needed to have available.

It is unacceptable for the banking entity to attempt to transfer the consequences arising from its lack of activity in this regard to the client.

In its allegations, CaixaBank seems to imply that such a lack of activity on its part must be supplemented by checks that the client must carry out or that there is an obligation on the part of the client to contact the bank's staff in order to obtain the proof of the banking operation they had carried out.

However, such proof (...).

Article 83.2 b) of the GDPR:

Intentionality or negligence:

In this case, serious negligence on the part of CaixaBank can be appreciated.

The Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard. (Ruling of the National Court of October 17, 2007 (rec. 63/2006)).

There can be no appreciation of rigor or exquisite care in the fact that CaixaBank detected the breach of personal data (...).

Nor can it be observed in the fact that (...).

Furthermore, it is striking that (...).

The fact that a breach is considered non-communicable does not exempt the entity from fulfilling its obligations regarding the registration of the same diligently and without excessive delays.

Likewise, the management cannot be qualified as diligent (...).

The fact that the banking entity overlooked (...) does not demonstrate diligent behavior on the part of said banking entity.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

107/121

Furthermore, it is considered appropriate to adjust the sanction to be imposed in accordance with the

criteria established in section 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD: Article 76. 2 b) of the LOPDGDD

b) The connection of the infringer's activity with the processing of personal data.

CaixaBank is a significant banking entity that routinely and continuously processes numerous personal data, both of its own clients and of clients from other banking entities whose data appears in the banking operations being carried out, as is the case with transfers.

It is aware of and applies the regulations regarding personal data protection.

Consequently, for the purposes of complying with the legally established requirements, the exercise of this activity necessarily implies knowledge and application of the current regulations on personal data protection.

In light of the facts presented, it is considered appropriate to impose a sanction on the party being claimed for the violation of Article 5. 1 f) of the GDPR.

The sanction to be imposed is an administrative fine in the amount of €2,000,000 (two million euros).

XIII Article 25.1 GDPR

Article 25.1 of the GDPR establishes the following:

“Data protection by design and by default

1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity posed by the processing to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of data subjects.”

In line with these provisions, Recital 78 of the GDPR states: (the underlining is ours)

“The protection of the rights and freedoms of natural persons with regard to the processing of personal data requires the adoption of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation. In order to demonstrate compliance with this Regulation, the data controller...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

108/121

The data controller must adopt internal policies and implement measures that comply, in particular, with the principles of data protection by design and by default. Such measures could consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of their data, and enabling the data controller to create and improve security elements. When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of these products, services, and applications should be encouraged to take into account the right to data protection when developing and designing these products, services, and applications, and to ensure, with due regard to the state of the art, that data controllers and processors are in a position to fulfill their obligations regarding data protection. The principles of data protection by design and by default must also be taken into account in the context of public contracts.

In particular, in light of Recital 78 of the GDPR, the principle of data protection by design is the key to be followed by the data controller to demonstrate compliance with the GDPR, as “the data controller must adopt internal policies and implement measures that comply, in particular, with the principles of data protection by design and by default.”

The principle of privacy by design is a demonstration of the shift from reactivity to proactivity and a direct manifestation of the risk-based approach imposed by the GDPR. As part of proactive responsibility, it requires that this principle be considered from the earliest stages of planning a

processing operation: the data controller, from the moment a potential processing of personal data is designed and planned, must determine all elements that constitute the processing, in order to effectively apply the principles of data protection, integrating the necessary safeguards into the processing with the ultimate aim of, in compliance with the provisions of the GDPR, protecting the rights of data subjects.

Thus, regarding the risks that may be present in the processing for the rights and freedoms of data subjects, the data controller shall carry out an analysis and detection of risks throughout the entire data processing cycle, with the primary and ultimate purpose of protecting the rights and freedoms of data subjects, and not only when the processing actually takes place. This is expressed in the Guidelines 4/2019 of the European Data Protection Board (EDPB) regarding Article 25 Data protection by design and by default, adopted on October 20, 2020.

In the aforementioned Guidelines, it is indicated that:

“35. The ‘moment of determining the means of processing’ refers to the period of time in which the controller is deciding how the processing will be carried out and how it will occur, as well as the mechanisms that will be used to carry out such processing. In the process of making such decisions, the data controller must evaluate the appropriate measures and safeguards to effectively apply the principles and rights of the data subjects.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

109/121

Interested parties in the processing, and take into account elements such as risks, the state of the art, and the cost of implementation, as well as the nature, scope, context, and purposes. This includes the moment of acquisition and implementation of software and hardware and data processing services.

36. Considering Data Protection by Design and by Default (DPDD) from the outset is crucial for the proper application of the principles and for the protection of the rights of the data subjects.

Furthermore, from a cost-effectiveness perspective, it is also in the interest of the data controllers to consider DPDD as early as possible, as it may later become difficult and costly to introduce changes to already formulated plans and designed processing operations.

To this end, when designing the processing, one must refer to the principles set out in Article 5 of the GDPR, which will serve to assess the effective compliance with the GDPR. Thus, the aforementioned Guidelines 4/2019 of the European Data Protection Board (EDPB) state that “61. To make DPDD effective, data controllers must apply the principles of transparency, lawfulness, fairness, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and proactive responsibility. These principles are enshrined in Article 5 and Recital 39 of the GDPR. (...)”

The Privacy by Design Guide of the Spanish Data Protection Agency (AEPD) states that “Privacy by Design (hereinafter, PbD) involves using a risk management and proactive responsibility approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, hardware or software product, service, or process). The lifecycle of the object refers to all the stages it goes through, from conception to withdrawal, including the phases of development, production, operation, maintenance, and withdrawal.”

The Guide provides that “Privacy must be an integral and inseparable part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed (...) Privacy is born in the design, before the system is operational, and must be guaranteed throughout the entire lifecycle of the data.”

Therefore, privacy by design, an obligation of the data controller that arises before the system is operational, is closely linked to a proactive and not reactive attitude. CaixaBank's actions in this case have been fundamentally reactive, responding to transfers, inspector requirements, initiation agreements, and evidence practice writings.

Linked to the building of a true culture of data protection within the organization, it also implies, due to

proactive responsibility, the ability to document all decisions made with a “privacy design thinking” approach, demonstrating compliance with the GDPR in this aspect as well.

The risk-based approach refers directly and immediately to a preventive system.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

110/121

to visualize, regarding the processing of personal data, the risks to the rights and freedoms of individuals.

In relation to the risks to the rights and freedoms of individuals, risks must be identified, their impact assessed, and the likelihood of their materialization evaluated. Thus, it is not the data that is protected, but the individuals behind it.

The risks to the rights and freedoms of individuals arising from the processing of personal data can vary in severity and likelihood and can cause physical, material, or immaterial harm, as well as tangible or intangible consequences, to the rights and freedoms of individuals. Recital 75 of the GDPR and Article 28.2 of the LOPDGDD exemplify some of the risks considered by the legislator, but they are not the only ones. It will depend on the processing and the context in which it is carried out, the personal data processed, the individuals involved, the means used, etc.

On the other hand, in the aforementioned Privacy by Design Guide from the AEPD, various guidelines are established: (the underlining is ours)

"Any system, process, or infrastructure that will use personal data must be conceived and designed from scratch by identifying, a priori, the possible risks to the rights and freedoms of the data subjects and minimizing them so that they do not materialize into harm. A Privacy by Design (PbD) policy is characterized by the adoption of proactive measures that anticipate threats, identifying the weaknesses of systems to neutralize or minimize risks instead of applying corrective measures to resolve security incidents once they have occurred. That is, PbD avoids the 'remedial policy' and anticipates the materialization of the risk event."

Privacy embedded in the design phase:

"Privacy must be an integral and inseparable part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed.

To ensure that privacy is taken into account from the earliest stages of design, the following must be done:

- Consider it a necessary requirement in the life cycle of systems and services, as well as in the design of the organization's processes.
- Conduct a risk analysis for the rights and freedoms of individuals and, where applicable, impact assessments related to data protection, as an integral part of the design of any new processing initiative.
- Document all decisions made within the organization with a 'privacy design thinking' approach.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

111/121

Respect for the privacy of users, maintaining a user-centered approach:

"Without overlooking the legitimate interests pursued by the organization through the processing of data it carries out, the ultimate goal must be to guarantee the rights and freedoms of users whose data is subject to processing, so any measures adopted must aim to ensure their privacy. This implies designing processes, applications, products, and services 'with the user in mind,' anticipating their

needs.

The user must have an active role in managing their own data and in controlling how others manage it. (...)"

In this legal basis, the content of legal basis VII (Analysis of the violation of Article 25 of the GDPR) is understood to be reproduced in its entirety, detailing the reasons why the AEPD understands that, in the case examined in this sanctioning file, the content of Article 25 of the GDPR has been violated.

XIV Qualification of the possible infringement of Article 25 GDPR and qualification for the purposes of prescription

The aforementioned infringement of Article 25 of the GDPR would constitute one of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines," states:

"Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

The LOPDGDD, for the purposes of the prescription of the infringement, qualifies in its Article 73.d) as a serious infringement, with a prescription period of two years in this case,

"d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the non-integration of the necessary guarantees in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679."

XV Sanction for the infringement of Article 25 of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

112/121

It is considered that the infringement in question is serious for the purposes of the GDPR and that it is appropriate to adjust the sanction to be imposed in accordance with the following criteria established in Article 83.2 of the GDPR:

The following circumstances are considered as aggravating:

Article 83.2 a) of the GDPR:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected data subjects and the level of damages suffered;

It is serious that a banking entity, with the relevance and volume of daily operations of CaixaBank (...). Furthermore, it is considered serious that despite having detected (...).

Article 83.2 b) of the GDPR:

b) the intentionality or negligence in the infringement;

While the Agency considers that there was no intentionality on the part of the banking entity, it concludes that its negligence was serious.

It should be noted that compliance with the principle of data protection by design is especially important in a financial entity, whose processing of personal data derived from continuous commercial legal traffic entails multiple risks to the rights and freedoms of individuals, such as identity theft, access to sensitive data, or the evident risk of a financial loss for the client who suffers the consequences.

The rigor and exquisite care in the handling of personal data mentioned in the Judgment of the National Court of October 17, 2007 (rec. 63/2006) is highlighted again.

That said, diligence cannot be appreciated (...).

The execution of that scheme, in the specific case we are analyzing, had the following consequences:

1. It was not detected that it was a claim regarding a personal data breach, being processed as a supposed claim for improperly charged receipts.

In the document from CaixaBank dated November 10, 2021 (proven fact thirteenth), it is highlighted: "(...)."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

113/121

Examining the content of the documentation submitted by the complainant along with their complaint, it is difficult to understand what verifications may have been carried out by the person who prepared the content of that document when processing a personal data breach as a claim for improperly charged receipts to a bank account.

2. (...).

3. As a third consequence, a financial entity cannot manage a personal data breach if it is unaware of its existence (despite having received a complaint regarding it).

Diligence cannot be appreciated in the (...).

In this second case, as seen in the legal basis VII, a non-transparent system was established, which shifts the entity's problems onto the client.

In the case of transfers, the fact that a solution was opted for (...), indicates improvisation; it is the opposite of a customer-oriented approach and cannot be considered as diligent behavior.

In this regard, the Guidelines 4/2019 of the EDPB state regarding the principle of fairness that "Data controllers should not transfer the risks of the business to the data subjects."

Rigor and exquisite care cannot be appreciated when (...).

That is to say, certain factors that contributed to the personal data breach remain latent and the (...) would allow for the recurrence of the combination of factors that caused the personal data breach.

Furthermore, it is considered appropriate to adjust the sanction to be imposed in accordance with the criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD: Article 76. 2 b) of the LOPDGDD

The following circumstance is considered as aggravating:

b) The link of the infringer's activity with the processing of personal data.

CaixaBank, in its business activity, regularly and continuously carries out the processing of numerous personal data, both of its own clients and of clients of other banking entities whose data appears in the banking operations being carried out, as is the case with transfers.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

114/121

Consequently, and for the purposes of complying with the legally established requirements, the exercise of this activity necessarily implies knowledge and application of the current regulations regarding the protection of personal data.

In light of the facts presented, it is considered appropriate to impose a sanction on the responding party for the violation of Article 25 of the GDPR.

The sanction to be imposed is an administrative fine in the amount of €1,500,000 (one million five hundred thousand euros).

XVI Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes: (the underlining is ours).

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

In this legal basis, the content of legal basis VI (Analysis of the violation of Article 32 of the GDPR) is understood to be reproduced in its entirety, detailing the reasons why the AEPD understands that, in the case examined in this sanctioning file, the content of Article 32 of the GDPR has been violated.

XVII Qualification of the infringement of Article 32 of the GDPR and qualification for the purposes of prescription

The aforementioned infringement of Article 32 of the GDPR would constitute one of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“4. Infringements of the following provisions shall be subject to administrative fines of up to €10,000,000 or, in the case of an undertaking, an amount equivalent to up to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the prescription period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

116/121

XVIII

****Sanction for the infringement of Article 32 of the GDPR****

The infringement in question is considered serious for the purposes of the GDPR, and it is appropriate to adjust the sanction to be imposed in accordance with the following criteria established by Article 83.2 of the GDPR:

The following circumstances are taken into account as aggravating factors:

****Article 83.2 a) of the GDPR:****

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or

purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage and harm they have suffered;

As stated in legal basis VI (Analysis of the breach of Article 32 of the GDPR), CaixaBank had not adequately fulfilled the obligation to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk in its procedure, as provided for in Article 32 of the GDPR.

It is serious that the (...).

In a context where security measures were deficient, it is serious that personal data breaches could occur, both in relation to operations (...) (as was the case with the update of contact data carried out by the complainant) (...) (this was the case of the transfer made by Mr. C.C.C.). That is to say, (...).

Finally, it is serious that (...), since we are talking about a financial entity with a high number of operations (...).

****Article 83.2 b) of the GDPR:****

b) the intentionality or negligence in the infringement;

While the AEPD considers that there was no intentionality on the part of the financial entity, it believes that its actions demonstrate serious negligence.

The deficiency of the security measures implemented by CaixaBank had consequences for part of the (...).

It is striking that when generating (...).

Furthermore, it is considered appropriate to adjust the sanction to be imposed in accordance with the criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

The following circumstance is considered as an aggravating factor:

****Article 76.2 b) of the LOPDGDD****

b) The link of the infringer's activity with the processing of personal data.

CaixaBank, in its business activity, regularly and continuously carries out the processing of numerous personal data, both of its own clients and of clients of other banking entities whose data appear in the banking operations being carried out, as is the case with transfers.

Consequently, for the purposes of compliance with the legally established requirements, the exercise of this activity necessarily implies knowledge and application of the current regulations on personal data protection.

In light of the facts presented, it is considered appropriate to impose a sanction on the respondent for the infringement of Article 32 of the GDPR.

The sanction to be imposed is an administrative fine in the amount of €1,500,000 (one million five hundred thousand euros).

XIX **Imposition of measures**

First, a response will be given to the allegation made by CaixaBank regarding the proposal for resolution concerning the imposition of measures.

In response to the proposed imposition of measures set forth in the proposal for resolution, the respondent expresses surprise at the requirement contained in the legal reasoning of the proposal for resolution, as the AEPD does not indicate why its adoption is necessary to adjust its processing activities to the provisions of the GDPR; the respondent reiterates that with the (...) it is sufficient to avoid the outcome analyzed by the AEPD, reducing the risk to zero for the rights and freedoms of the data subjects; it also claims that it has (...). It alleges that (...). In summary, it cannot deduce what the corrective measures are, which leaves it defenseless.

On this particular matter, a series of issues must be indicated.

The first is that the AEPD has provided since the initiation agreement, through the proposal for resolution, the possibility of imposing measures. And this is in consideration of the facts recorded in the initiation agreement and the proven facts stated in the proposal for resolution that determined the necessity for the respondent to adjust its processing to the provisions of the GDPR.

And all this by virtue of the corrective powers granted to the AEPD as the supervisory authority in Article 58.2 of the GDPR.

In fact, in this case, measures have been specifically imposed with the proposal for resolution, a procedural moment in which the proven facts have been established that clearly determine what the

breaches of the GDPR are that the respondent has incurred, following a phase of proof, composed of three testing practices.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

118/121

No surprise, therefore, can represent for the respondent what has been warned and indicated to them from the beginning. Throughout the entire process followed in the AEPD - from the filing of the complaint, through the transfer, the preliminary investigative actions, and the sanctioning procedure - the respondent has addressed some issues related to their non-compliance due to the transfer, requirement, or evidence gathering by the AEPD, reactively and not proactively, but not everything and not completely, in light of the text of the resolution.

Second, the administrative resolution has not only determined in detail and with precision the background and the proven facts from which the infringements attributed to CaixaBank are concluded, but it has also undermined the presumption of innocence of the entity, perfectly demonstrating and justifying what the non-compliances with the GDPR by the respondent are.

In contrast, the respondent limits themselves to denying their non-compliance, without providing sufficient elements to demonstrate that they have complied with the GDPR.

An undeniable indication that they are not correctly applying, for example, privacy by design, is evident in the allegations now examined when they reiterate that the (...).

The respondent makes this absolute assertion without any evidence to support it, (...), in addition to what such an assertion implies in terms of ignorance of data protection regulations, which considers that risks are in continuous evolution, making it necessary to adopt the necessary measures against such changing risks.

Moreover, what is asserted is not true, since the (...), without any risk being identified or evaluated. It also results that such an assertion represents an evident contradiction with their own subsequent actions, given the changes made in their procedure when the AEPD itself warns them in the initiation agreement of the (...). If the risk to the rights and freedoms of the interested parties was zero after the (...), they will have to explain the reasons for the subsequent modifications.

Third, the text of the resolution establishes and proves what the constitutive facts of the infringement have been that determine the need for compliance with data protection regulations, from which it is clearly inferred what measures need to be adopted, as these measures must aim to resolve the non-compliances detected by the AEPD, complying with the GDPR.

Thus, for example, and without any intention of being exhaustive, from a simple reading of the administrative resolution, it is observed that, regarding the specific personal data breach suffered by the complainant due to the lack of availability of their personal data and evidenced by the AEPD, the respondent has ultimately made available to the client the personal data concerning them in full regarding the operation carried out on (...).

However, regarding the implementation of appropriate technical and organizational measures of all kinds derived from the application of privacy by design, among other issues, the determination and establishment of those they claim to have implemented have not been approached from the risks to the rights and freedoms of the interested parties (but rather from the risks to the organization), nor is the system managed proactively, in such a way that compliance with privacy has not been achieved.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

119/121

from the design. Therefore, the measures that the responding party claims to have strictly implemented regarding data protection are not sufficient, and the responding party must carry out all necessary actions to correctly apply privacy by design within the framework of compliance management as provided by the GDPR, in accordance with its proactive responsibility.

In summary, each and every one of the GDPR violations by the responding party is clearly outlined in the proposed resolution and in the resolution itself, from which the measures to be adopted can be inferred.

All of this is without prejudice to the fact that the specific types of procedures, mechanisms, or instruments for implementing them correspond to the sanctioned party, as it is the data controller who fully understands its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

In any case, the responding party has a DPO who, in compliance with the functions assigned by Article 39 of the GDPR, must inform and advise it, as well as supervise compliance with the GDPR, also assisting in implementing the necessary corrective measures.

Therefore, the alleged defenselessness is not considered to exist.

In fact, this Agency does not believe that we are facing a problem of defenselessness, nor a lack of detailed motivation on the part of the AEPD regarding the infringements committed and the corresponding corrective measures imposed, nor even a difficulty in understanding the proposed resolution. Rather, such an allegation of defenselessness responds more to a simple defense strategy of the responding party: it seeks to justify its defenselessness based on the claim that it has complied with the GDPR and, therefore, no longer knows what else it needs to do.

However, this is not the case, as evidenced and substantiated throughout this administrative resolution.

CaixaBank has violated the GDPR; it has not adopted, throughout the sanctioning procedure, all necessary measures to comply with current legislation, and it is up to the Agency, in accordance with the powers conferred upon it, to impose corrective measures so that the treatments of the data controller comply with the GDPR and protect the rights and freedoms of all individuals whose personal data is processed, with the aim of preventing the risks from materializing again in the future.

Therefore, based on what has just been stated, and in relation to the imposition of measures on CaixaBank, it is important to highlight that:

The text of the resolution establishes what the facts are that determine the need for compliance with data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the specific types of procedures, mechanisms, or instruments for implementing them correspond to the sanctioned party, as it is the data controller who fully understands its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

120/121

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Article 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE CAIXABANK, S.A., with NIF A08663619, a fine of €2,000,000.00 (two million euros) for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR.

SECOND: TO IMPOSE CAIXABANK, S.A., with NIF A08663619, a fine of €1,500,000 (one million five hundred thousand euros) for an infringement of Article 25 of the GDPR, classified under Article 83.4 of the GDPR.

THIRD: TO IMPOSE CAIXABANK, S.A., with NIF A08663619, a fine of €1,500,000 (one million five hundred thousand euros) for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR.

FOURTH: TO ORDER CAIXABANK, S.A., with NIF A08663619, pursuant to Article 58.2.d) of the

GDPR, to notify the Agency of the adoption of the measures within nine months, in light of the content of legal basis XIX.

FIFTH: TO NOTIFY this resolution to CAIXABANK, S.A.

SIXTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

The sanctioned party is warned that they must comply with the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, to the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

121/121

In accordance with the provisions of Article 76.4 of the LOPDGDD and given that the amount of the imposed sanction exceeds one million euros, the information identifying the infringer, the infringement committed, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal.

If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

938-250923

Mar España Martí

Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es